



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temario para la preparación de la Oposición al Cuerpo Superior de
Sistemas y Tecnologías de la Información de la Administración del
Estado.

TEMAS ESPECÍFICOS – BLOQUE B
II. TECNOLOGÍA BÁSICA

**82. Adaptación de aplicaciones y entornos a los requisitos de
la normativa de protección de datos según los niveles de
seguridad. Herramientas de cifrado y auditoría**

AUTOR: Elisa Martín Ortega.

REVISOR: Nuria Establés Rodríguez.

Creación: septiembre 2022

Actualización:

ÍNDICE

1	INTRODUCCION	5
2	ESTÁNDARES NACIONALES E INTERNACIONALES.....	6
3	ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD	7
3.1	INTRODUCCIÓN.....	7
3.2	NORMATIVA Y MARCO JURÍDICO APLICABLE.....	7
3.3	PRINCIPIOS EN EL RGPD.....	8
3.4	ROLES EN LA PROTECCIÓN DE DATOS	9
3.4.1	RESPONSABLE DEL TRATAMIENTO	9
3.4.2	ENCARGADO DEL TRATAMIENTO	9
3.4.3	DELEGADO DE PROTECCIÓN DE DATOS.....	10
3.5	ADAPTACIÓN DE LAS APLICACIONES Y ENTORNOS.....	11
3.5.1	DEBER DE INFORMACIÓN	11
3.5.2	CONSENTIMIENTO EXPRESO.....	12
3.5.3	MINIMIZACIÓN DE LOS DATOS.....	13
3.5.4	SEUDONIMIZACIÓN O ANONIMIZACIÓN	14
3.5.5	MEDIDAS DE SEGURIDAD	15
3.5.5.1	MEDIDAS EN EL ENS.....	16
3.5.5.1.1	Datos personales [mp.info.1]	21
3.5.5.1.2	Protección de la confidencialidad [mp.com.2]	22
3.5.5.1.3	Calificación de la información [mp.info.2]	23
3.5.5.1.4	Limpieza de documentos [mp.info.5]	23
3.5.5.1.5	Borrado y destrucción [mp.si.5]	24
3.5.5.1.6	Criptografía [mp.si.2]	24
3.5.5.2	HERRAMIENTAS AEPD	25
3.5.6	ANÁLISIS DE RIESGOS	27
3.5.7	EVALUACIÓN DE IMPACTO.....	29

3.5.8	PORTABILIDAD DE LOS DATOS	32
3.5.9	DERECHO DE SUPRESIÓN.....	32
3.6	RESPUESTA A INCIDENTES Y NOTIFICACIÓN DE BRECHAS DE SEGURIDAD	37
3.7	CONCLUSIÓN.....	40
4	HERRAMIENTAS DE CIFRADO Y AUDITORÍA	41
4.1	INTRODUCCIÓN	41
4.2	HERRAMIENTAS DE CIFRADO	41
4.2.1	NORMATIVA Y MARCO JURÍDICO APLICABLE	41
4.2.2	ALGORITMO DE CIFRADO	44
4.2.3	APLICACIÓN DEL CIFRADO	44
4.2.4	PRODUCTOS CUALIFICADOS.....	45
4.2.5	LISTADO DE MECANISMOS CRIPTOGRÁFICOS AUTORIZADOS.....	46
4.2.6	LA CLAVE PÚBLICA COMO DATO PERSONAL	47
4.3	AUDITORÍA	47
4.3.1	NORMATIVA	47
4.3.2	EL PROCESO DE AUDITORÍA.....	48
4.3.3	BENEFICIOS DEL PROCESO DE AUDITORÍA.....	52
4.3.4	CONTENIDO DEL INFORME DE AUDITORÍA	52
4.3.5	CONTRATACIÓN DE SERVICIOS DE AUDITORÍA	53
4.3.6	HERRAMIENTAS DE AYUDA A LA AUDITORÍA	53
4.3.6.1	ASSI-RGPD	53
4.3.6.2	GESTIONA	53
4.3.6.3	PILAR.....	54
4.3.6.4	AMPARO	55
4.3.7	AUDITORÍA E INTELIGENCIA ARTIFICIAL	58
4.4	CONCLUSIÓN.....	58
5	ACTUALIDAD Y TENDENCIAS FUTURAS	60
6	RESUMEN ESQUEMÁTICO	61
7	GLOSARIO	65

8	TEST	66
8.1	PREGUNTAS DE TEST	66
8.2	SOLUCIONES A LAS PREGUNTAS DE TEST	69
9	BIBLIOGRAFÍA BÁSICA.....	70
9.1	BIBLIOGRAFÍA BÁSICA	70
9.2	BIBLIOGRAFÍA PARA AMPLIAR EL TEMA.....	71

1 INTRODUCCION

En el presente documento se desarrolla el tema 82 del temario para la preparación de la Oposición al Cuerpo Superior de Sistemas y Tecnologías de la Información de la Administración del Estado y que pertenece al bloque B, parte 2 que tiene por título Tecnología Básica.

El tema se dividirá en dos apartados principales:

1. Adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos según los niveles de seguridad.
2. Herramientas de cifrado y auditoría.

Estos apartados tienen relación con otros temas del temario, a los que se hace referencia en la introducción de cada uno de ellos.

Para atender al objetivo de este tema se debe tener presente, en primer lugar, las dos normas fundamentales en materia de protección de datos personales, el Reglamento General de Protección de Datos (RGPD) de obligado cumplimiento para todos los Estados Miembros, y la Ley Orgánica de Protección de Datos y Garantía de Derechos Digitales (LOPDDGG) en el ámbito nacional.

Además, es fundamental tener en cuenta el Esquema Nacional de Seguridad (ENS) en relación con el establecimiento de las medidas de carácter técnico y organizativo, los preceptos en materia de auditoría, análisis de riesgos y gestión y comunicación de incidentes, así como el Esquema Nacional de Interoperabilidad (ENI), en particular importante por su relación con la política de gestión de documentos electrónicos.

2 ESTÁNDARES NACIONALES E INTERNACIONALES.

Además de la normativa, instrucciones y guías de ámbito nacional que serán nombradas en el desarrollo de este tema, los principales estándares internacionales en esta materia son:

- ISO/IEC 27000 para la implementación de la seguridad de la información, destacando la ISO/IEC 27001 respecto al Sistema de Gestión de la Seguridad de la Información, la ISO/IEC 27002 como conjunto de buenas prácticas, y la 27005 para la gestión de riesgos en los sistemas de información.
- NIST SP-800 que presenta el catálogo de controles relativos a la privacidad y seguridad en los sistemas de información y las organizaciones.

3 ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD

3.1 INTRODUCCIÓN

El presente punto tiene por objeto la adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos según los niveles de seguridad, no pretende hacer un desarrollo completo de la normativa de protección de las personas físicas en lo que respecta al tratamiento de datos personales que es tratada explícitamente en el tema 27.

En la adaptación de las aplicaciones y los entornos a los requisitos de la normativa de protección de datos, es necesario tener en cuenta los principios y obligaciones establecidos por el Reglamento General de Protección de Datos (RGPD), la Ley Orgánica de Protección de Datos y Garantía de Derechos Digitales (LOPDDGG) y el cumplimiento de las medidas de seguridad establecidas en el Anexo II del Esquema Nacional de Seguridad (ENS).

3.2 NORMATIVA Y MARCO JURÍDICO APLICABLE

En la adaptación de las aplicaciones y los entornos a los requisitos de la normativa de protección de datos, se deben tener en cuenta las siguientes normas básicas:

1. EL REGLAMENTO (UE) 2016/679 DEL PARLAMENTO EUROPEO Y DEL CONSEJO de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE, comúnmente conocido en España como RGPD de sus siglas, Reglamento general de protección de datos, (GDPR en sus siglas en inglés). Este reglamento, como tal, es directamente aplicable y de obligado cumplimiento por todos los Estados miembros, y entró en vigor a los 20 días de su publicación, pero existió un periodo transitorio hasta su plena aplicación con fecha 25 de mayo de 2018.
2. La Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, que adapta el ordenamiento español al Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de sus datos personales y a la libre circulación de estos datos y otorga seguridad jurídica, derogando la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal, el Real Decreto-ley 5/2018, de 27 de julio, de medidas urgentes para la adaptación del Derecho español a la normativa de la Unión Europea en materia de protección de datos,

así como, el resto de disposiciones de igual o inferior rango que contradigan, se opongan, o resulten incompatibles con lo dispuesto en el Reglamento (UE) 2016/679.

3. La Directiva (UE) 2016/680 relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales por parte de las autoridades competentes para fines de prevención, investigación, detección o enjuiciamiento de infracciones penales o de ejecución de sanciones penales, y a la libre circulación de dichos datos.
4. El Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad, como desarrollo y perfección del Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.

Además, en el año 2021 se amplió el uso de las medidas del ENS al ámbito de las infracciones penales con la publicación en 2021 de la Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales, estableciendo en su artículo 37 la obligación de aplicar las medidas del ENS a los tratamientos de datos personales por parte de las autoridades públicas competentes.

3.3 PRINCIPIOS EN EL RGPD

El Reglamento General de Protección de Datos en su artículo 5 señala un conjunto de principios que los responsables y encargados del tratamiento deben observar al tratar datos personales, algunos de ellos tienen relación directa con la aplicación de medidas para la adaptación de sistemas y aplicaciones:

1. Principio de licitud, transparencia y lealtad en el tratamiento de los datos.
2. Principio de finalidad, que determina que los datos deben ser tratados con una o varias finalidades determinadas, explícitas y legítimas, prohibiendo que los datos recogidos sean tratados posteriormente de forma incompatible con esos fines.
3. Principio de minimización de datos, aplicando las medidas técnicas y organizativas que garanticen que el tratamiento sea específico de la finalidad, limitando además su accesibilidad y plazo de conservación.
4. Principio de exactitud, que tiene por objeto que los datos estén actualizados y se supriman o modifiquen en cuanto sean inexactos con respecto a la finalidad.
5. Principio de limitación del plazo de conservación, por el que los datos deben borrarse, bloquearse o anonimizarse una vez la finalidad ha sido alcanzada.
6. Principio de seguridad por el que los responsables y encargados se ven obligados a realizar un análisis de riesgos que les permita determinar las medidas técnicas y organizativas para asegurar la integridad, disponibilidad y confidencialidad de los datos.

Además, podría considerarse el principio de responsabilidad activa que obliga a los responsables a mantener la diligencia de forma permanente para proteger y garantizar los derechos y libertades de las personas físicas de cuyos datos realizan un tratamiento.

3.4 ROLES EN LA PROTECCIÓN DE DATOS

El RGPD establece tres roles en materia de protección de datos: el responsable del tratamiento, el encargado del tratamiento y el delegado de protección de datos.

A continuación, se muestran las obligaciones establecidas para cada uno de ellos, según el RGPD, en todo caso, puede consultarse mayor detalle sobre estos roles en el tema 27.

3.4.1 RESPONSABLE DEL TRATAMIENTO

Para proteger y garantizar los derechos y libertades de las personas físicas cuyos datos son tratados, y a la vez que, para demostrar el cumplimiento, el RGPD incorpora una serie de obligaciones en cumplimiento del principio de responsabilidad proactiva.

A continuación, se detallan las obligaciones del responsable, sin perjuicio de otras que pudieran ser necesarias para el objetivo de garantizar y proteger los derechos y libertades de las personas físicas cuyos datos son tratados.

1. Registro de actividades de tratamiento.
2. Inventario de actividades de tratamiento.
3. Designación de un delegado de protección de datos.
4. Evaluación del riesgo que, para los derechos y libertades de los interesados, podría suponer un tratamiento de datos personales.
5. Realización de evaluaciones de impacto para la protección de datos.
6. Consulta previa.
7. Protección de datos desde el diseño.
8. Protección de datos por defecto.
9. Seguridad de los tratamientos de datos.
10. Notificación de brechas de datos personales a la Autoridad de Control.
11. Comunicación de brechas de datos personales a los interesados.
12. Elaboración de códigos de conducta.
13. Establecimiento de garantías para las transferencias de datos personales a terceros países u organizaciones internacionales.

3.4.2 ENCARGADO DEL TRATAMIENTO

En el desarrollo, implantación y mantenimiento de los sistemas de información, aplicaciones y entornos es habitual que participen equipos de desarrollo, soporte y administración que en ocasiones serán

servicios ofrecidos por proveedores, además de los responsables de servicios y coordinadores de las áreas TIC de la organización, sin olvidar a los propios responsables funcionales de dichos sistemas. Todos estos grupos podrían ser considerados encargados de tratamiento.

El RGPD establece en el artículo 28 que la relación entre responsable y encargado del tratamiento quedará vinculada por un contrato u acto jurídico con arreglo al Derecho de la Unión o de los Estados miembros. Este mismo artículo establece las siguientes obligaciones del encargado del tratamiento:

1. Tratar los datos personales únicamente siguiendo instrucciones documentadas del responsable.
2. Garantizar que las personas autorizadas para tratar datos personales se hayan comprometido a respetar la confidencialidad.
3. Tomar todas las medidas necesarias de acuerdo con el artículo 32.
4. Respetar las condiciones establecidas por el RGPD cuando el encargado recurra a su vez a otro encargado.
5. Asistir al responsable, teniendo cuenta la naturaleza del tratamiento, a través de medidas técnicas y organizativas, para que este pueda cumplir con su obligación de responder a las solicitudes que tengan por objeto el ejercicio de los derechos de los interesados.
6. Ayudar al responsable a garantizar el cumplimiento de las obligaciones establecidas en los artículos 32 a 36 del RGPD con respecto a la seguridad.
7. A elección del responsable, suprimir o devolver todos los datos personales una vez finalice la prestación de los servicios de tratamiento, y suprimir las copias existentes a menos que se requiera la conservación de los datos personales en virtud del Derecho de la Unión o de los Estados miembros.
8. Poner a disposición del responsable toda la información necesaria para demostrar el cumplimiento de sus obligaciones establecidas.

3.4.3 DELEGADO DE PROTECCIÓN DE DATOS.

Las administraciones públicas deberán designar un Delegado de Protección de Datos, según queda establecido en la sección 4 del RGPD y en el capítulo III de la LOPDGDD.

Las funciones principales del delegado de protección de datos son:

1. Informar y asesorar al responsable o al encargado del tratamiento y a los empleados que se ocupen del tratamiento de sus obligaciones en materia de protección de datos personales.
2. Supervisar el cumplimiento del RGPD y la LOPDGDD, incluida la asignación de responsabilidades, la concienciación y formación del personal que participa en las operaciones de tratamiento, y las auditorías.
3. Ofrecer el asesoramiento que se le solicite acerca de la evaluación de impacto relativa a la protección de datos y supervisar su aplicación.
4. Cooperar con la autoridad de control.

5. Actuar como punto de contacto de la autoridad de control para cuestiones relativas al tratamiento, incluida la consulta previa.

3.5 ADAPTACIÓN DE LAS APLICACIONES Y ENTORNOS

Resultado de las obligaciones y para regirse por los principios, las organizaciones deberán realizar un conjunto de tareas en la adecuación a la normativa de protección de datos, entre las más destacadas están:

1. Realizar un análisis sobre la organización, la información y los sistemas.
2. Nombrar un Delegado de Protección de Datos que deberá actuar dentro de una completa estructura orgánica de gestión de seguridad de la información.
3. Elaborar el Registro de actividades de tratamiento (RAT) analizando y determinando las bases jurídicas de los tratamientos y su finalidad. Posteriormente, realizar su mantenimiento.
4. Realizar un inventario y desarrollar los consentimientos y las cláusulas de derecho de información. Si estos ya existiesen, se deberán actualizar con las exigencias del RGPD.
5. Llevar a cabo el análisis de riesgos que ayude a determinar la necesidad o no de realizar una evaluación de impacto.
6. Si el análisis realizado en el anterior punto resulta de alto riesgo, se deberá realizar una Evaluación de Impacto conforme a las directrices del Grupo de Trabajo del Artículo 29.
7. Elaborar un marco documental completo, comenzando con la Política de Seguridad de la Información y la Política de Protección de Datos, y continuando con el resto de los procedimientos, entre ellos, el procedimiento de gestión de derechos de los titulares y registro de atención de derechos.
8. Llevar a cabo un plan de formación y concienciación en la seguridad de la información y la protección de datos.
9. El seguimiento y control periódicos por parte de los responsables en seguridad de la información y en la protección de datos.

En base a estas tareas, a continuación, se determinan las medidas a llevar a cabo para la adaptación de las aplicaciones y los entornos a la protección de datos personales según a los siguientes apartados:

3.5.1 DEBER DE INFORMACIÓN

En las aplicaciones antes de proceder a la recogida de información, se debe informar al interesado afectados en dos niveles. En primer lugar, se ofrecerá una información básica y resumida, y en caso de ser de interés para la persona afectada, se ofrecerá acceso a una segunda capa con información adicional y detallada.

En todo caso, la información ofrecida deberá presentarse en un lenguaje conciso, claro y sencillo. Ambas capas deberán contener los siguientes epígrafes:

1. Responsable del tratamiento.
2. Finalidad del tratamiento.
3. Legitimación del tratamiento.
4. Destinatarios de cesiones o transferencias.
5. Derechos de las personas interesadas.
6. Procedencia de los datos.

La primera capa de información deberá contener:

1. La identidad del responsable del tratamiento.
2. Una descripción sencilla de los fines del tratamiento y la elaboración de perfiles.
3. La base jurídica del tratamiento.
4. Si está previsto o no realizar cesiones o transferencia a terceros países.
5. La forma de llevar a cabo el ejercicio de sus derechos.
6. La procedencia de los datos cuando esta no sea el propio interesado.

La segunda capa de información deberá contener:

1. Los datos de contacto del responsable, del representante y del Delegado de Protección de Datos.
2. Una descripción ampliada de los fines de tratamiento con los plazos y criterios de conservación de los datos, y si existiesen las decisiones automatizadas, elaboración de perfiles y lógica.
3. La base jurídica del tratamiento, en los casos que esté basada en la obligación legal, interés público o interés legítimo, así como la obligación o no de facilitar datos y las consecuencias de su negativa.
4. Los destinatarios o categorías de destinatarios en las cesiones y transferencias, así como la adecuación, garantías y normas corporativas vinculantes.
5. Información detallada sobre como ejercer los derechos de acceso, rectificación, supresión, portabilidad, limitación u oposición, así como la forma de retirar el consentimiento expreso y la forma de realizar una reclamación ante la Autoridad de Control. Los plazos de acceso, rectificación, cancelación y oposición serán de un mes, debiéndose dar la posibilidad de ser realizados de forma telemática.
6. Detalle sobre el origen de los datos, así como sus categorías. Esta información se ofrecerá incluso cuando su origen sea de acceso público.

3.5.2 CONSENTIMIENTO EXPRESO

En las aplicaciones el consentimiento expreso deberá ser inequívoco, explícito y elegido de forma libre, es decir, deja de ser válido el consentimiento tácito.

En el registro del tratamiento deberá ser posible demostrar su existencia por lo que, por ejemplo, deberá incorporarse en la aplicación una casilla que tenga que firmar el usuario, o que la selección de

parámetros que ha llevado a cabo en la declaración quede perfectamente grabada, por ejemplo, en una base de datos para poder ser consultada y demostrar el acto del interesado.

En la redacción de estos consentimientos se deberá tener en cuenta que sea redactado en un lenguaje claro y sencillo.

Además, cuando se preste consentimiento al tratamiento de múltiples finalidades, por ejemplo, en el marco de contratos o declaraciones, deberá habilitarse que el interesado pueda dar el consentimiento por cada una de ellas de forma diferenciada, y deberá ser grabada cada una de las selecciones realizadas en la base de datos.

Para las aplicaciones ya existentes que cumpliesen la anterior normativa de protección de datos (LOPD 15/1999) y que hubiesen recabado el consentimiento de forma conforme a lo que establece el RGPD, no será necesario volver a recabarlo. Sin embargo, si el consentimiento se recogió de forma tácita, deberá obtenerse un nuevo consentimiento. Esta obligación fue el motivo del conjunto de solicitudes de consentimiento que recibieron los interesados antes del 25 de mayo de 2018, fecha en la que era plenamente aplicable.

En todas las aplicaciones se deberá ofrecer información detallada de la forma que se habilita para que el interesado puede retirar o revocar el consentimiento.

3.5.3 MINIMIZACIÓN DE LOS DATOS

El artículo 25 del RGPD establece la minimización y la limitación en la accesibilidad a los datos como una de las medidas de protección de datos desde el diseño y por defecto. Las estrategias principales para llegar a la protección desde el diseño son.

1. Minimizar: recoger y tratar la mínima cantidad de datos posibles (selección, exclusión, eliminación tras el período de conservación).
2. Abstraer: limitar el uso de los datos personales (mediante generalizaciones de valores de atributos, agrupaciones e introducción de perturbaciones en vez de uso de datos exactos).
3. Separar: evitar el perfilado de sujetos (mediante recogida y almacenamiento aislado de datos personales y la diseminación del tratamiento en subconjuntos independientes).
4. Ocultar: limitando la exposición de los datos personales (restringir acceso, ofuscando datos para que sean inteligibles, disociando los datos para que sean independientes y agregación para evitar correlaciones).

La principal vía para cumplir con este requisito es un análisis funcional adecuado del sistema que se implementa, así como una recogida de información selectiva de los únicos datos necesarios limitando la petición de aquellos que no sean necesarios.

Existen servicios que pueden ser utilizados para evitar el almacenamiento de datos personales, es importante en caso de utilizar estos servicios, hacerlo de forma que la implementación no ponga en riesgo el tratamiento.

Un ejemplo puede ser el uso de la Plataforma de Intermediación de Datos (PID) para verificar el número de soporte del DNI de un usuario que accede a una sede electrónica. Este servicio es ofrecido por la Dirección General de la Policía, y permite verificar el dato aportado por un usuario como medio de identificación, de modo que el ciudadano aporta su número de DNI y su número de soporte, el organismo envía ambos a través de la PID para su verificación por la Dirección General de la Policía, la cual contesta si la pareja es válida o no, sin dar más información. Este servicio es muy útil para ofrecer el acceso a servicios que no requieren de una alta seguridad a ciudadanos que no disponen de certificado electrónico, pero es muy importante implementarlo de forma que no se quede almacenado ningún número de soporte en la base de datos del organismo y solo se utilicen los datos personales en la comunicación que deberá estar cifrada.

Otra técnica que puede utilizarse en este objetivo son las pruebas de conocimiento cero o nulo (ZKP) que permite demostrar que se dispone de una información sin exponerla mediante el empleo del mecanismo de hash y el uso de un tercero de confianza asegurando la integridad.

Puede consultarse un ejemplo de esta técnica en el artículo publicado por la AEPD con título [Cifrado y Privacidad IV: Pruebas de conocimiento cero](#).

Estos ejemplos y otros que pueden utilizarse son conceptos teóricos o matemático robustos, pero hay que prestar atención de no realizar una implementación incorrecta, que en todo caso debería revelarse con una gestión de riesgos y auditorías adecuada.

3.5.4 SEUDONIMIZACIÓN O ANONIMIZACIÓN

Según establece el considerando 26 del RGPD, *“los principios de protección de datos no deben aplicarse a la información anónima, es decir información que no guarda relación con una persona física identificada o identificable, ni a los datos convertidos en anónimos de forma que el interesado no sea identificable, o deje de serlo”*, en la medida en que no se puede atribuir a una persona física sin información adicional, es decir a los datos anonimizados no le aplica el RGPD, aunque pueden estar afectados por otras normas de seguridad.

En las aplicaciones y entornos de los sistemas de información, es posible generar datos anonimizados a partir de datos personales aplicando una transformación que debe asegurar que la información adicional no permite la reidentificación.

En todo caso, el conjunto de datos seudonimizados, la información vinculada y el tratamiento que genera estos datos si están bajo el ámbito del RGPD y protegido sus garantías, según el artículo 4.5 del RGPD y por tanto en las aplicaciones habrá que tener en cuenta que:

1. Ha de impedirse la reidentificación sin disponer de la información adicional.
2. A estos datos le aplican todas las limitaciones, finalidad, periodo de conservación, comunicación, etc.

3. Aplicar las medidas determinadas en base al análisis de riesgos para proteger los derechos y libertades.
4. Aplicar las medidas técnicas y organizativas que impidan la materialización de brechas.

Es importante diferenciar estos dos conceptos, *“El tratamiento de anonimización genera un único y nuevo conjunto de datos, mientras que el tratamiento de seudonimización genera dos nuevos conjuntos de datos: la información seudonimizada y la información adicional que permite revertir la anonimización.”*

Una técnica utilizada en las aplicaciones habitualmente para la seudonimización son las funciones hash por su propiedad de irreversible o la muy baja probabilidad de ser reversible con la capacidad de cómputo actual y con una fortaleza determinada de la clave.

En el análisis de riesgos que se lleve a cabo periódicamente por la organización, se deberá prestar especial atención a las funciones hash implantadas y aplicar las medidas técnicas que protejan de una materialización de amenazas debido al riesgo de dejar en claro datos personales. Además de las medidas técnicas deberá tenerse en cuenta las medidas organizativas establecidas para la eliminación de la información que permite la reidentificación y la garantía de robustez en el tiempo.

En todo caso el proceso de anonimización debe ser robusto también en relación con el responsable del tratamiento que no debe ser capaz en ningún caso de reidentificar a las personas físicas de los datos anonimizados. Es decir, el responsable de la información no debe ser una excepción, y que pueda acceder a los datos sin anonimizar.

3.5.5 MEDIDAS DE SEGURIDAD

La determinación del marco que determina las medidas de seguridad a aplicar queda establecida por el RGPD y la LOPDDGG, y el propio ENS:

El Artículo 32 de título Seguridad del tratamiento del Reglamento General de Protección de Datos, en adelante RGPD, que dice:

Artículo 32. Seguridad del tratamiento

1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*

d) *un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

La Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, comúnmente, conocida como LOPDGDD, establece en su Disposición adicional primera, de título *Medidas de seguridad en el ámbito del sector público*, que las medidas de seguridad a implantar para el tratamiento de datos personales serán los determinados por el Esquema Nacional de Seguridad.

Disposición adicional primera. Medidas de seguridad en el ámbito del sector público.

1. El Esquema Nacional de Seguridad incluirá las medidas que deban implantarse en caso de tratamiento de datos personales para evitar su pérdida, alteración o acceso no autorizado, adaptando los criterios de determinación del riesgo en el tratamiento de los datos a lo establecido en el artículo 32 del Reglamento (UE) 2016/679.

2. Los responsables enumerados en el artículo 77.1 de esta ley orgánica deberán aplicar a los tratamientos de datos personales las medidas de seguridad que correspondan de las previstas en el Esquema Nacional de Seguridad, así como impulsar un grado de implementación de medidas equivalentes en las empresas o fundaciones vinculadas a los mismos sujetas al Derecho privado.

En los casos en los que un tercero preste un servicio en régimen de concesión, encomienda de gestión o contrato, las medidas de seguridad se corresponderán con las de la Administración pública de origen y se ajustarán al Esquema Nacional de Seguridad.

La selección de las medidas deberá ser proporcionales y tener en cuenta el estado de la técnica, los costes, la naturaleza, alcance, contexto y fines de los tratamientos, y los riesgos para los derechos y libertades de los ciudadanos. Además, para determinar las medidas a aplicar se deberá tener en cuenta los activos a proteger, la dimensión y categoría de seguridad del sistema de información en el que se realice el tratamiento de los datos.

3.5.5.1 MEDIDAS EN EL ENS

El anexo II del ENS presenta las medidas divididas en tres grupos:

1. Marco organizativo
2. Marco operacional
3. Medidas de protección

Con la publicación del nuevo ENS en 2022 se han actualizado muchas de las medidas del Anexo II y se ha incorporado cuando es necesario determinados refuerzos a los requisitos generales.

En relación con la protección de datos es necesario tener en cuenta todas las recomendaciones, si así lo determina el análisis de riesgos y debido a la mención exhaustiva de la normativa a este respecto que hace referencias a medidas respecto a:

1. Las que permiten realizar el cifrado y la seudonimización.
2. Aquellas que garantizan la confidencialidad, integridad, disponibilidad y resiliencia de los sistemas y servicios.
3. Aquellas que garantizan la continuidad del negocio.
4. Aquellas que permiten la monitorización y la auditoría.

Se consideran especialmente necesarias las siguientes:

1. Todas las medidas organizativas y que forman parte de la propia implantación de la gestión de la seguridad de la información.
2. Las medidas de operación relacionadas con el control de acceso [op.acc.2], con los mecanismos de control de autenticación de usuarios externos [op.acc.5] e internos [op.acc.6], con la gestión de incidentes [op.exp.7] y su registro [op.exp.9], con el registro de la actividad [op.exp.8], con la protección de las claves criptográficas [op.exp.10]
3. Las medidas técnicas de protección en la identificación de las personas [mp.if.2], la concienciación [mp.per.3], la formación [mp.per.4], el bloqueo de los puestos de trabajo [mp.eq.2] y de los dispositivos portátiles [mp.eq.3], todas las relacionadas con la protección de las comunicaciones [mp.com], y en particular las de protección de la confidencialidad [mp.com2], todas las relacionadas con los soportes de información [mp.si], todas las relacionadas con la protección de la información [mp.info], de las aplicaciones informáticas [mp.sw], todas las relacionadas con la protección de la información en partículas la destinada a los datos personales [mp.info.1] y las que aplican a la limpieza de documentos [mp.info.5]

Los requisitos de las medidas se determinan en base al nivel de seguridad (bajo, medio o alto) y son importantes las descritas anteriormente, en concreto las que afectan a la dimensión de la confidencialidad, según se indica en las tablas del Anexo II.

ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD

Medidas de Seguridad	Por categoría o dimensión(es)	Nivel de las dimensiones de seguridad		
		BAJO	MEDIO	ALTO
		Categoría de seguridad del sistema		
		BÁSICA	MEDIA	ALTA
org	Marco organizativo			
org.1	Política de seguridad	Categoría	aplica	aplica
org.2	Normativa de seguridad	Categoría	aplica	aplica
org.3	Procedimientos de seguridad	Categoría	aplica	aplica
org.4	Proceso de autorización	Categoría	aplica	aplica
op	Marco operacional			
op.pl	Planificación			
op.pl.1	Análisis de riesgos	Categoría	aplica	+ R1
op.pl.2	Arquitectura de Seguridad	Categoría	aplica	+ R1 + R2 + R3
op.pl.3	Adquisición de nuevos componentes	Categoría	aplica	aplica
op.pl.4	Dimensionamiento/gestión de la capacidad	D	aplica	+ R1
op.pl.5	Componentes certificados	Categoría	n.a.	aplica
op.acc	Control de acceso			
op.acc.1	Identificación	T A	aplica	+ R1
op.acc.2	Requisitos de acceso	C I T A	aplica	+ R1
op.acc.3	Segregación de funciones y tareas	C I T A	n.a.	+ R1
op.acc.4	Proceso de gestión de derechos de acceso	C I T A	aplica	aplica
op.acc.5	Mecanismo de autenticación (usuarios externos)	C I T A	+ [R1 o R2 o R3 o R4]	+ [R2 o R3 o R4] + R5
op.acc.6	Mecanismo de autenticación (usuarios de la organización)	C I T A	+ [R1 o R2 o R3 o R4] + R8 + R9	+ [R1 o R2 o R3 o R4] + R5 + R6 + R7 + R8 + R9
op.exp	Explotación			
op.exp.1	Inventario de activos	Categoría	aplica	aplica
op.exp.2	Configuración de seguridad	Categoría	aplica	aplica
op.exp.3	Gestión de la configuración de seguridad	Categoría	aplica	+ R1 + R2 + R3
op.exp.4	Mantenimiento y actualizaciones de seguridad	Categoría	aplica	+ R1 + R2
op.exp.5	Gestión de cambios	Categoría	n.a.	+ R1
op.exp.6	Protección frente a código dañino	Categoría	aplica	+ R1 + R2 + R3 + R4
op.exp.7	Gestión de incidentes	Categoría	aplica	+ R1 + R2 + R3
op.exp.8	Registro de la actividad	T	aplica	+ R1 + R2 + R3 + R4 + R5
op.exp.9	Registro de la gestión de incidentes	Categoría	aplica	aplica

Ilustración 1. Medidas de seguridad del Anexo II del ENS, primera parte. Fuente: ENS publicado en 2022

ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD

	Medidas de Seguridad	Por categoría o dimensión(es)	BAJO	MEDIO	ALTO
			Categoría de seguridad del sistema		
			BÁSICA	MEDIA	ALTA
op.exp.10	Protección de claves criptográficas	Categoría	aplica	+ R1	+ R1
op.ext	Recursos externos				
op.ext.1	Contratación y acuerdos de nivel de servicio	Categoría	n.a.	aplica	aplica
op.ext.2	Gestión diaria	Categoría	n.a.	aplica	aplica
op.ext.3	Protección de la cadena de suministro	Categoría	n.a.	n.a.	aplica
op.ext.4	Interconexión de sistemas	Categoría	n.a.	aplica	+ R1
op.nub	Servicios en la nube				
op.nub.1	Protección de servicios en la nube	Categoría	aplica	+ R1	+ R1 + R2
op.cont	Continuidad del servicio				
op.cont.1	Análisis de impacto	D	n.a.	aplica	aplica
op.cont.2	Plan de continuidad	D	n.a.	n.a.	aplica
op.cont.3	Pruebas periódicas	D	n.a.	n.a.	aplica
op.cont.4	Medios alternativos	D	n.a.	n.a.	aplica
op.mon	Monitorización del sistema				
op.mon.1	Detección de intrusión	Categoría	aplica	+ R1	+ R1 + R2
op.mon.2	Sistema de métricas	Categoría	aplica	+ R1 + R2	+ R1 + R2
op.mon.3	Vigilancia	Categoría	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4 + R5 + R6
mp	Medidas de protección				
mp.if	Protección de las instalaciones e infraestructuras				
mp.if.1	Áreas separadas y con control de acceso	Categoría	aplica	aplica	aplica
mp.if.2	Identificación de las personas	Categoría	aplica	aplica	aplica
mp.if.3	Acondicionamiento de los locales	Categoría	aplica	aplica	aplica
mp.if.4	Energía eléctrica	D	aplica	+ R1	+ R1
mp.if.5	Protección frente a incendios	D	aplica	aplica	aplica
mp.if.6	Protección frente a inundaciones	D	n.a.	aplica	aplica
mp.if.7	Registro de entrada y salida de equipamiento	Categoría	aplica	aplica	aplica
mp.per	Gestión del personal				
mp.per.1	Caracterización del puesto de trabajo	Categoría	n.a.	aplica	aplica
mp.per.2	Deberes y obligaciones	Categoría	aplica	+ R1	+ R1
mp.per.3	Concienciación	Categoría	aplica	aplica	aplica
mp.per.4	Formación	Categoría	aplica	aplica	aplica
mp.eq	Protección de los equipos				
mp.eq.1	Puesto de trabajo despejado	Categoría	aplica	+ R1	+ R1

Ilustración 2. Medidas de seguridad del Anexo II del ENS, segunda parte. Fuente: ENS publicado en 2022

ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD

	Medidas de Seguridad	Por categoría o dimensión(es)	Nivel de las dimensiones de seguridad		
			BAJO	MEDIO	ALTO
			Categoría de seguridad del sistema		
			BÁSICA	MEDIA	ALTA
mp.eq.2	Bloqueo de puesto de trabajo	A	n.a.	aplica	+ R1
mp.eq.3	Protección de dispositivos portátiles	Categoría	aplica	aplica	+ R1 + R2
mp.eq.4	Otros dispositivos conectados a la red	C	aplica	+ R1	+ R1
mp.com	Protección de las comunicaciones				
mp.com.1	Perímetro seguro	Categoría	aplica	aplica	aplica
mp.com.2	Protección de la confidencialidad	C	aplica	+ R1	+ R1 + R2 + R3
mp.com.3	Protección de la integridad y de la autenticidad	I A	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
mp.com.4	Separación de flujos de información en la red	Categoría	n.a.	+ [R1 o R2 o R3]	+ [R2 o R3] + R4
mp.si	Protección de los soportes de información				
mp.si.1	Marcado de soportes	C	n.a.	aplica	aplica
mp.si.2	Criptografía	C I	n.a.	aplica	+ R1 + R2
mp.si.3	Custodia	Categoría	aplica	aplica	aplica
mp.si.4	Transporte	Categoría	aplica	aplica	aplica
mp.si.5	Borrado y destrucción	C	aplica	+ R1	+ R1
mp.sw	Protección de las aplicaciones informáticas				
mp.sw.1	Desarrollo de aplicaciones	Categoría	n.a.	+ R1 + R2 + R3 + R4	+ R1 + R2 + R3 + R4
mp.sw.2	Aceptación y puesta en servicio	Categoría	aplica	+ R1	+ R1
mp.info	Protección de la información				
mp.info.1	Datos personales	Categoría	aplica	aplica	aplica
mp.info.2	Calificación de la información	C	n.a.	aplica	aplica
mp.info.3	Firma electrónica	I A	aplica	+ R1 + R2 + R3	+ R1 + R2 + R3 + R4
mp.info.4	Sellos de tiempo	T	n.a.	n.a.	aplica
mp.info.5	Limpieza de documentos	C	aplica	aplica	aplica
mp.info.6	Copias de seguridad	D	aplica	+ R1	+ R1 + R2
mp.s	Protección de los servicios				
mp.s.1	Protección del correo electrónico	Categoría	aplica	aplica	aplica
mp.s.2	Protección de servicios y aplicaciones web	Categoría	+ [R1 o R2]	+ [R1 o R2]	+ R2 + R3
mp.s.3	Protección de la navegación web	Categoría	aplica	aplica	+ R1
mp.s.4	Protección frente a denegación de servicio	D	n.a.	aplica	+ R1

Ilustración 3. Medidas de seguridad del Anexo II del ENS, tercera parte. Fuente: ENS publicado en 2022

Las medidas establecidas en esta guía son el mínimo necesario que se debe implementar, o justificar los motivos por los cuales no se implementan o se sustituyen por otras medidas de seguridad con los que deberían alcanzarse la misma protección para la información y los servicios.

Una vez realizado el análisis que determine las medidas necesarias a implantar para la protección de las aplicaciones y entornos, sus responsables pueden ayudarse con el uso de la guía CCN-STIC 804 publicada por el CCN-CERT que tiene por título [ENS. Guía de Implantación](#)

Por ejemplo, es habitual que las aplicaciones y entornos tengan en cuenta las siguientes medidas, lo que permitirá reducir las brechas de seguridad:

1. Sistemas de cifrado de la información y seudonimización, tanto en comunicaciones, por ejemplo, con VPN, como en almacenamiento, incluido en dispositivos que podrían sufrir pérdidas o robos. Estos sistemas de cifrado serán explicados en el siguiente punto.
2. Asignación de permisos mínimos al crearse usuarios, así que, como el control de las credenciales, y la retirada cuando no sean necesarias.
3. Sistemas de autenticación segura, por ejemplo, los basados en doble factor, token de un solo uso, biométrica, etc.
4. Control de uso de contraseñas seguras en base a lo determinado por la política de contraseñas como un apartado de la política de seguridad de la información.
5. Realización de copias de seguridad como medida de recuperación ante el secuestro de datos personales.
6. No usar datos reales en los entornos de desarrollo y preproducción no utilizar datos reales.
7. Prestar especial cuidado a los logs de registros de actividad, de forma que no incorporen datos personales.

Se describen a continuación las medidas más destacadas en relación con la confidencialidad, pero como se indicaba se debe hacer un análisis de riesgos que determine la totalidad de medidas a implantar en el sistema de información. Puede consultarse mayor detalle en el tema 48, en el anexo II del ENS y en la guía de implantación CCN-STIC 804.

En la guía CCN-STIC 808 puede haber alguna diferencia de numeración en la identificación con las medidas del ENS recientemente publicado, por ejemplo, la medida de limpieza de documentos en el nuevo ENS tiene el identificativo [mp.info.5] y en la guía 804 aparece como [mp.info.6] como aparecía en el ENS publicado en 2010.

3.5.5.1.1 DATOS PERSONALES [MP.INFO.1]

Puede consultarse el detalle de estas medidas en el tema 48, pero se transcribe aquí el punto relacionado con los datos personales [mp.info.1].

dimensiones	Todas		
categoría	BÁSICA	MEDIA	ALTA
	aplica	aplica	aplica

Ilustración 4. Requisitos de la medida Datos personales. Fuente: Anexo II del ENS publicado en 2022

El anexo II del ENS establece que cuando el sistema incorpore datos personales, el responsable de seguridad deberá acogerse a los requisitos en esta materia contando con el asesoramiento del Delegado de Protección de Datos, y teniendo en cuenta, si ha sido necesario, el resultado de la Evaluación de Impacto. A su vez, la guía 804 enumera la normativa a tener en cuenta en la implantación de esta medida [mp.info.1]

3.5.5.1.2 PROTECCIÓN DE LA CONFIDENCIALIDAD [MP.COM.2]

Respecto a la protección de las comunicaciones, en concreto con relación a la confidencialidad, el anexo II del ENS establece que es necesario emplear redes privadas virtuales cifradas cuando la comunicación discurra por redes fuera del propio dominio de seguridad en todos los niveles de seguridad. Además, Incorporando con el concepto de refuerzos del nuevo ENS, un refuerzo para el nivel medio y tres para el nivel alto.

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	aplica	+ R1	+R1+R2+R3

Ilustración 5. Requisitos de la medida Protección de la confidencialidad. Fuente: Anexo II del ENS publicado en 2022

Estos refuerzos consisten en:

Refuerzo R1-Algoritmos y parámetros autorizados.

–[mp.com.2.r1.1] Se emplearán algoritmos y parámetros autorizados por el CCN.

Refuerzo R2-Dispositivos hardware.

–[mp.com.2.r2.1] Se emplearán, dispositivos hardware en el establecimiento y utilización de la red privada virtual.

Refuerzo R3-Productos certificados.

–[mp.com.2.r3.1] Se usarán productos o servicios que cumplan lo establecido en [op.pl.5].

Refuerzo R4-Cifradores.

–[mp.com.2.r4.1] Se emplearán cifradores que cumplan con los requisitos establecidos en la guía CCN-STIC que sea de aplicación.

Refuerzo R5-Cifrado de información especialmente sensible.

–[mp.com.2.r5.1] Se cifrará toda la información transmitida.

La guía de implantación del ENS CCN-STIC 804 determina que las medidas [mp.com.2] y [mp.com.3] deben implantarse de forma conjunta utilizando algoritmos acreditados por el CCN y recurriendo a redes virtuales privadas para las conexiones fuera del dominio de la organización. En el cifrado de las

comunicaciones se debe prestar especial cuidado a las redes inalámbricas, en concreto, en la generación y distribución de las claves en las que se basa y utilizar algoritmo y productos cualificados y acreditados.

3.5.5.1.3 CALIFICACIÓN DE LA INFORMACIÓN [MP.INFO.2]

El anexo II del ENS establece que la calificación de la información se llevará a cabo para los sistemas de información con nivel de seguridad medio y alto. La calificación se realizará en base a las leyes y tratados internacionales de los que España es miembro y su normativa de aplicación cuando se trate de materias clasificadas. El valor a emplear en el caso de información de materias no clasificadas sería USO OFICIAL para información con algún tipo de restricción en su manejo por su sensibilidad y confidencialidad.

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	n.a.	aplica	aplica

Ilustración 6. Requisitos de la medida Calificación de la información. Fuente: Anexo II del ENS publicado en 2022

En la Política de Seguridad de la Información se deberá identificar cada uno de los responsables de cada información manejada en el sistema de información, que tendrá entre sus funciones determinar el nivel de seguridad requerido para la información de la que es responsable.

En los aspectos organizativos se podrá seguir lo establecido en la guía CCN-STIC 801 para la definición de responsabilidades y roles.

El proceso de calificación de la información es un proceso complejo que debe ser acorde a otros sistemas de calificación de la organización, así como al anexo I del ENS, en concreto, con el establecimiento de forma clara de las responsabilidades.

3.5.5.1.4 LIMPIEZA DE DOCUMENTOS [MP.INFO.5]

El anexo II del ENS determina, que en el proceso de limpieza de documentos, se retirará de estos toda la información adicional contenida en campos ocultos, metadatos, comentarios o revisiones anteriores, salvo cuando dicha información sea pertinente para el receptor del documento.

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	aplica	aplica	aplica

Ilustración 7. Requisitos de la medida Limpieza de documentos. Fuente: Anexo II del ENS publicado en 2022

3.5.5.1.5 BORRADO Y DESTRUCCIÓN [MP.SI.5]

El anexo II de ENS establece que es un requisito común a todos los niveles de seguridad el que los soportes que vayan a ser reutilizados para otra información o liberados a otra organización sean objeto del borrado seguro de su contenido de modo que no permita su recuperación y cuando la naturaleza del soporte no permita un borrado seguro, el soporte no podrá ser reutilizado en ningún otro sistema.

dimensiones	C		
nivel	BAJO	MEDIO	ALTO
	aplica	+ R1	+ R1

Ilustración 8. Requisitos de la medida Borrado y destrucción. Fuente: Anexo II del ENS publicado en 2022

El mecanismo de destrucción será proporcionado a la clasificación de la información contenida y tendrá en cuenta la normativa de protección medioambiental y los certificados de calidad medioambiental de la organización.

En el caso de sistemas categorizados con nivel medio y alto de seguridad, además deberán utilizarse productos cualificados según el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (CPSTIC) del CCN, además de ser destruidos cuando finalice su ciclo de vida, para lo que se utilizarán los productos cualificados en el catálogo.

Los refuerzos establecidos son:

Refuerzo R1-Productos certificados.

–[mp.si.5.r1.1] Se usarán productos o servicios que cumplan lo establecido en [op.pl.5].

Refuerzo R2 - Destrucción de soportes.

–[mp.si.5.r2.1] Una vez finalizado el ciclo de vida del soporte de información, deberá ser destruido de forma segura conforme a los criterios establecidos por el CCN.

3.5.5.1.6 CRIPTOGRAFÍA [MP.SI.2]

El anexo II del ENS determina que esta medida debe aplicarse a partir del nivel medio de seguridad a todos los dispositivos removibles cuando salen de un área controlada. Estos mecanismos criptográficos deberán garantizar no solo la confidencialidad, sino por también la integridad y, en todo caso, emplear algoritmos autorizados por el CCN. Para los sistemas con un nivel de seguridad alto además deberán utilizarse productos certificados conforme al catálogo CPSTIC y no olvidar aplicar esta medida a las copias de seguridad.

dimensiones	C I		
nivel	BAJO	MEDIO	ALTO
	n.a.	aplica	+ R1 + R2

Ilustración 9. Requisitos de la medida Criptografía. Fuente: Anexo II del ENS publicado en 2022

Los refuerzos establecidos son:

Refuerzo R1– Productos certificados.

–[mp.si.2.r1.1] Se emplearán productos certificados conforme a lo establecido en [op.pl.5].

Refuerzo R2-Copias de seguridad.

–[mp.si.2.r2.1] Las copias de seguridad se cifrarán utilizando algoritmos y parámetros autorizados por el CCN.

Esta medida junto a la de cifrado, se explican en mayor detalle en el apartado HERRAMIENTAS DE CIFRADO Y AUDITORÍA.

3.5.5.2 HERRAMIENTAS AEPD

Adicionalmente al ENS y la guía 804, la AEPD ha publicado en Junio de 2021 la guía de título [Gestión del riesgo y evaluación de impacto en tratamientos de datos personales](#), de ayuda al cumplimiento por parte de los responsables de las obligaciones en los tratamientos y que incluye la metodología de gestión de riesgos para los derechos y libertades y la Evaluación de Impacto para la Protección de Datos, y que puede ayudar a determinar las medidas en aspectos de más puro enfoque de la protección de datos.

Además, la AEPD ofrece la herramienta FACILITA dirigida a empresas y accesible desde la URL <https://gestion.aepd.es/>, esta herramienta realiza tres preguntas iniciales sobre el sector de la organización, finalidad de los datos y tratamientos que se realizan para determinar si los tratamientos son considerados de bajo riesgo y el uso de FACILITA es adecuado, o debe acudir a otras herramientas y a un servicio más especializado. Aunque la herramienta está dirigida a empresas puede ser útil como guía en el caso de trabajar con tratamientos de escaso riesgo.





¿Su organización trata datos personales de clientes (personas físicas)?

Se refiere a datos personales de aquellas personas con las que usted mantiene una relación comercial.

☒ Sí ☐ No

A continuación marque qué datos personales trata de sus clientes

☐ Identificación (nombre, apellidos, NIF, dirección postal, teléfono, email)

☐ Características personales (estado civil, fecha y lugar de nacimiento, edad, sexo, nacionalidad)

☐ Datos académicos

☐ Datos bancarios

Marque para qué utiliza los datos personales que solicita a sus clientes

☐ Prestarles un servicio

☐ Facturar

☐ Enviar publicidad postal o por correo electrónico

☐ Servicio postventa y fidelización

Marque a quien entrega los datos personales de sus clientes

Cumplimiento de obligaciones legales:

☐ Agencia Estatal de Administración Tributaria

☐ Instituto Nacional de la Seguridad social

☐ Bancos y entidades financieras

☐ Fuerzas y Cuerpos de Seguridad

☐ Otros

Otros:

☐ Gestoría



Ilustración 10. Herramienta FACILITA, sección de identificación de la organización. Fuente página web de la AEPD

Una vez indicado los datos identificativos de la organización y los datos personales que se utilizan de empleados, clientes, candidatos, proveedores, etc., se permite la descarga de un documento a modo plantilla con el contenido mínimo a rellenar para el cumplimiento del RGPD, y que incorpora textos genéricos que pueden usarse como base, acceso a formularios de ejemplo a utilizar para permitir el ejercicio de cada uno de los derechos, etc.



Ilustración 11. Herramienta FACILITA, página de finalización del proceso. Fuente página web de la AEPD

El documento generado con la herramienta sirve de ayuda para dar cumplimiento a los requisitos de las medidas organizativas en materia de protección de datos, ya que permite elaborar las cláusulas informativas en los formularios de solicitud de información, tanto en papel, como a través de su página web, y revisar los contratos ya existentes o modificar los nuevos con las nuevas cláusulas contractuales.

Tan importante como la implantación de las medidas, es su revisión periódica para asegurar el cumplimiento y que los sistemas siguen estando protegidos.

Además, se puede tener en cuenta las herramientas EVALUA-RIESGOS, GESTIONA, y FACILITA EMPRENDE <https://www.aepd.es/es/guias-y-herramientas/herramientas/facilita-emprende>.

3.5.6 ANÁLISIS DE RIESGOS

El RGPD establece que cuando existen tratamientos de datos personales, es necesario realizar una gestión del riesgo con el fin de determinar las medidas para garantizar los derechos y libertades de las personas.

La AEPD ofrece la herramienta EVALÚA_RIESGO RGPD que facilita a responsables y encargados la identificación de factores de riesgo para los derechos y libertades de las personas interesadas, permitiendo una primera evaluación de riesgo intrínseco, así como el riesgo residual tras la utilización de medidas y garantías de mitigación.

En todo caso, los factores de riesgo desplegados son generales, y el responsable deberá determinar los específicos de su caso para determinar con mayor exactitud su nivel de riesgo tanto el inicial, como el residual.

La herramienta EVALUA_RIESGO RGPD es un archivo Excel con una macro que puede descargarse desde este enlace [Evalúa-Riesgo RGPD](#). Este archivo tiene distintas páginas en las que se van solicitando información relativa a los factores de riesgo, y ayuda con comentarios sobre la celda con ejemplos de la información solicitada. Por cada uno de los factores de riesgo se tiene que indicar si aplica o no el factor de riesgo y el resultado de la mitigación entre uno de los siguientes:

1. No mitigado.
2. Limitadamente mitigado.
3. Significativamente mitigado.
4. Mitigado

OPERACIONES RELACIONADAS CON LOS FINES DE TRATAMIENTO		
SIN DEFINIR	Aplicabilidad	Mitigación
Perfilado		
Evaluación de sujetos		
Predicción		
Control del empleado		
Control de acceso a internet		
Observación		
Monitorización		
Supervisión		
Rastreo de contactos		
Control físico de acceso		
Localización		
Identificación unívoca		
Decisiones Automatizadas sin intervención humana		
Tratamiento automatizado para soporte a toma de decisiones		
Decidir sobre, o impedir, el ejercicio de derechos fundamentales		
Decidir sobre el control del interesado de sus datos personales		
Decidir sobre el acceso a un servicio		
Decidir sobre la realización o ejecución de un contrato		
Decidir sobre el acceso a servicios financieros		

Factores de riesgo
 otros fines vinculados

P. ej. y sin ser exhaustivos:

- Control de acceso al centro de trabajo
- Control de acceso a local comercial
- Control de acceso a eventos
- Control de acceso a instalaciones deportivas
- Control de acceso a edificios (públicos/privados)
- Otros

Ilustración 12. Herramienta EVALUA_RIESGO RGPD. Fuente: Página web de la AEPD

En concreto el responsable deberá aportar el estado de la mitigación de los factores de riesgos que deriven de las operaciones llevadas a cabo que derivan del fin declarado de tratamiento y otros fines vinculados al propósito general.

1. El ámbito del tratamiento de los datos recogidos, procesados o inferidos en el tratamiento.
2. Los sujetos afectados, la diversidad de datos o aspectos tratados, la duración en el tiempo, el volumen de datos, la extensión geográfica, la exhaustividad sobre la persona, la frecuencia de recogida, etc.
3. La categoría de interesados, como empleados, menores, mayores, personas en situación de vulnerabilidad, víctimas, discapacitados, etc.
4. La naturaleza del tratamiento al implementarse en los sistemas de información con determinadas tecnologías o características técnicas.
5. La naturaleza del tratamiento al recogerse o generarse datos de forma específica.

6. El contexto del tratamiento al poder generarse consecuencias no contempladas en los propósitos originales previstos del tratamiento. Para este caso particular, además de indicar si aplican o no los factores de riesgo enumerados en la herramienta, se deberá indicar la probabilidad de que las amenazas se materialicen.
7. El contexto de la actividad, modelo de negocio o tipo de entidad.
8. El contexto en el que se realizan las comunicaciones de datos a terceros en el marco del tratamiento.
9. Adicionalmente, se ofrece una hoja para que el responsable pueda identificar 10 factores de riesgo específicos de su tratamiento.
10. Por último, se solicitan si aplica o no, la probabilidad, el impacto y el resultado de la mitigación de los factores de riesgos que se deriven de la materialización de brechas de seguridad sobre los datos personales.

Como resultado se obtienen la valoración de riesgo intrínseco, el residual en base a las medidas y el listado de factores de riesgo, además esta información puede obtenerse en un informe.

The screenshot displays the 'EVALÚA_RIESGO RGPD' web application. At the top left is the AEPD logo (Agencia Española de Protección de Datos) and the date 'viernes, 2 de julio de 2021'. The main content area shows two columns: 'VALORACIÓN RIESGO INTRÍNSECO' and 'VALORACIÓN RIESGO RESIDUAL', both resulting in 'RIESGO BAJO' (Low Risk) indicated by green bars. To the right are buttons for 'Informe' (Report), 'Imprimir' (Print), and 'Volver a Inicio' (Return to Home). Below the results, the 'INFORME' section shows the text: 'resultado de valoración de riesgo intrínseco: El resultado de valoración de riesgo residual es: RIESGO BAJO RIESGO BAJO'. At the bottom, there is a section for 'LISTADO DE FUENTES DE RIESGO POR CATEGORÍAS' with a note: 'Pulse el botón Informe para generar listado de factores de riesgo.'

Ilustración 13. Herramienta EVALUA_RIESGO RGPD, página de resultados. Fuente: Página web de la AEPD

3.5.7 EVALUACIÓN DE IMPACTO

Cuando existen tratamientos de datos personales, el RGPD en su artículo 35 establece la necesidad de realizar una gestión del riesgo con el fin de determinar las medidas para garantizar los derechos y libertades de las personas a las que hace referencia el anterior apartado.

En el caso particular en que estos tratamientos impliquen un riesgo alto para la protección de datos, se establece la obligación de realizar una Evaluación de Impacto en Protección de Datos para mitigar esos riesgos, ejemplos de estos tratamientos son: la elaboración de perfiles, tratamientos a gran escala de

categorías especiales de datos (orientación sexual, afiliación sindical, datos genéticos, convicciones religiosas, datos biométricos que definan unívocamente a una persona, datos de salud, etc.) u observación sistemática de una zona de acceso público.

Respecto al EIPD, es importante tener en cuenta los siguientes aspectos:

1. Es exigible cuando hay un alto riesgo para los derechos y libertades.
2. Es una obligación específica del responsable.
3. Exige un análisis de la necesidad y proporcionalidad del tratamiento con relación a sus fines.
4. Exige su realización antes del inicio de las actividades de tratamiento.
5. Su resultado se debe tener en cuenta para evaluar la viabilidad o inviabilidad del tratamiento desde el punto de vista de protección de datos.
6. Exige el asesoramiento del DPD si este está nombrado.

En definitiva, el EIPD se trata de un proceso, que ayuda a mitigar los riesgos antes de tratar datos personales, para que el tratamiento se realice con garantías de que se respetarán los derechos y libertades de los propietarios de los datos, y que resulta obligatoria en algunos casos establecidos por el RGPD.

La AEPD ha publicado la guía de título [Gestión del riesgo y evaluación de impacto en tratamientos de datos personales](#), que se acompaña de un [listado de verificación](#) a modo de *checklist*, para facilitar a los responsables de tratamiento la comprobación de que el trabajo realizado, proceso y documentación, para la elaboración de la Evaluación de Impacto en la Protección de Datos cumple los elementos mínimos exigidos.

El cumplimiento de esta lista de verificación, en particular, es necesaria cuando el responsable del tratamiento va a realizar una consulta previa a la AEPD, según la establece la instrucción 1/2021 de la Agencia.

A continuación, se muestra el esquema básico del proceso de gestión del riesgo incluyendo la EIPD.

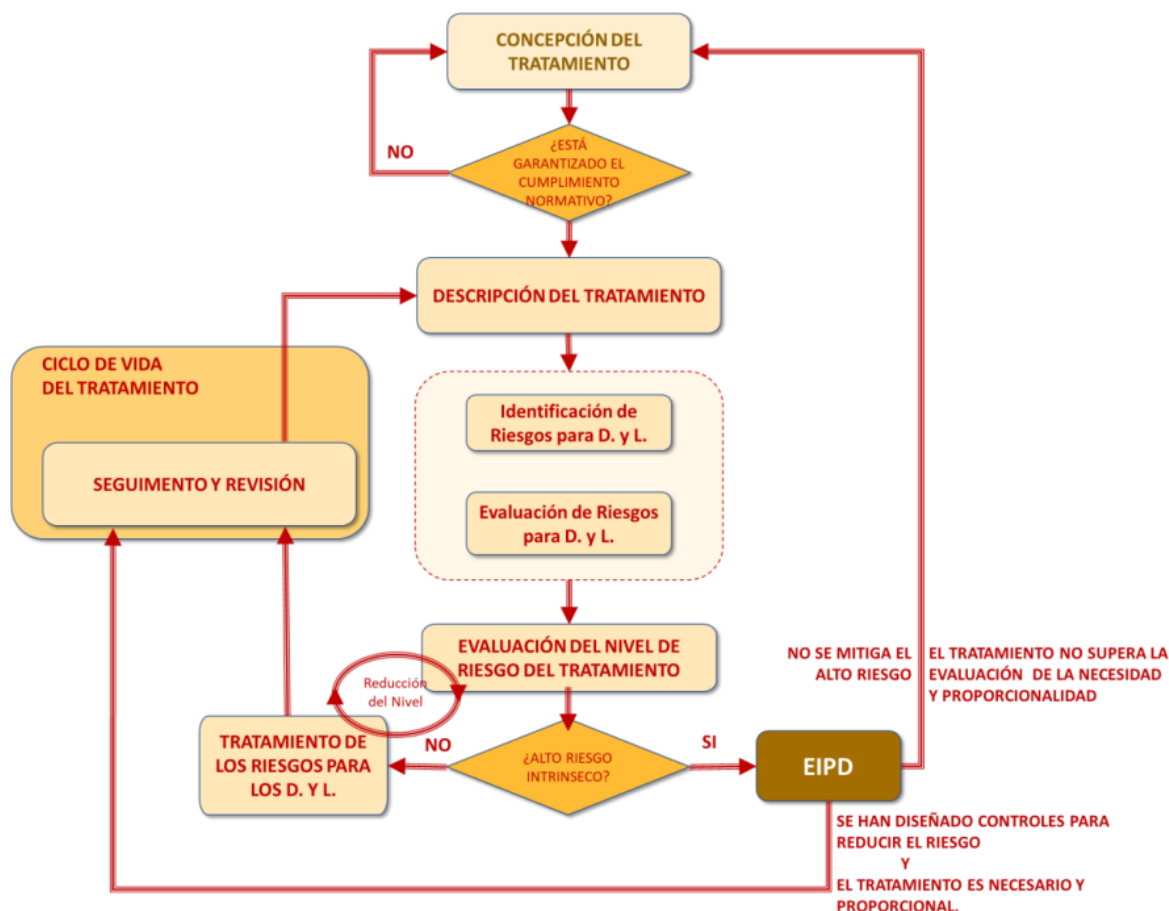


Ilustración 14. Esquema básico del proceso de gestión del riesgo incluyendo la EIPD. Fuente: Guía de Gestión del riesgo y evaluación de impacto en tratamientos de datos personales.

El contenido mínimo de una EIPD es el siguiente:

1. Una descripción sistemática de las operaciones de tratamiento previstas y de los fines del tratamiento, inclusive, cuando proceda, el interés legítimo perseguido por el responsable del tratamiento.
2. Una evaluación de la necesidad y la proporcionalidad de las operaciones de tratamiento con respecto a su finalidad.
3. Una evaluación de los riesgos para los derechos y libertades de los interesados
4. Las medidas previstas para afrontar los riesgos, incluidas garantías, medidas de seguridad y mecanismos que garantizan la protección de datos personales, y a demostrar la conformidad con el presente Reglamento, teniendo en cuenta los derechos e intereses legítimos de los interesados y de otras personas afectadas.

El responsable se puede ayudar de la herramienta publicada por la AEPD en el siguiente enlace: <https://gestion.aepd.es/>, para determinar si es necesaria una EIPD y elaborarla.

← → ↻ gestiona.aepd.es 🔍 📄

¡importante! Los datos proporcionados se guardaran de forma local en su navegador

Análisis de la necesidad de realizar una EIPD

1 Tipos de operaciones específicamente considerados por la Autoridad de control 2 3 4 5 6 7 8

¿El tratamiento a analizar se encuentra dentro de la lista de tipos de tratamientos de datos publicados por la AEPD que requieren una EIPD? ⓘ

Tratamientos que impliquen perfilado o valoración de sujetos, incluida la recogida de datos del sujeto en múltiples ámbitos de su vida (desempeño en el trabajo, personalidad y comportamiento), que cubran varios aspectos de su personalidad o sobre sus hábitos.

Tratamientos que impliquen la toma de decisiones automatizadas o que contribuyan en gran medida a la toma de tales decisiones, incluyendo cualquier tipo de decisión que impida a un interesado el ejercicio de un derecho o el acceso a un bien o un servicio o formar parte de un contrato.

Tratamientos que impliquen la observación, monitorización, supervisión, geolocalización o control del interesado de forma sistemática y exhaustiva, incluida la recogida de datos y metadatos a través de redes, aplicaciones o en zonas de acceso público, así como el procesamiento de identificadores únicos que permitan la identificación de usuarios de servicios de la sociedad de la información como pueden ser los servicios web, TV interactiva, aplicaciones móviles, etc.

Ilustración 15. Herramientas de Evaluación de impacto. Fuente: <http://gestiona.aepd.es>

3.5.8 PORTABILIDAD DE LOS DATOS

En el artículo 20 del RGPD se establece que siempre que el tratamiento esté basado en el consentimiento y/o se efectúe por medios automatizados, el interesado tendrá derecho a recibir los datos personales que le incumban, que haya facilitado a un responsable del tratamiento, en un formato estructurado, de uso común y lectura mecánica, y a transmitirlos a otro responsable. Este artículo tiene relación directa con la interoperabilidad entre aplicaciones.

Para poder asegurar la portabilidad de los datos, las aplicaciones y entornos deberán generar y almacenar estos de forma que puedan ofrecerse en un formato estructurado, de uso común y legible por máquina, en este sentido el formato XML es adecuado para dar respuesta.

Para que los datos ofrecidos por los responsables del tratamiento sean realmente portables, junto con los datos se debe proporcionar también los metadatos suficientes y con el mayor detalle para preservar el significado exacto de la información.

Esta obligación es importante tenerla en cuenta desde el diseño de las aplicaciones para que la recogida de la información ya genere los metadatos suficientes para su eventual portabilidad.

El Grupo de Trabajo del Artículo 29 publicó un documento en relación con este aspecto de la [portabilidad de los datos](#).

3.5.9 DERECHO DE SUPRESIÓN

El derecho de supresión, también llamado derecho al olvido se restringe al ámbito digital según establece el artículo 93 de la LOPDGDD en relación con las búsquedas de Internet y el artículo 94 en relación con las redes sociales y servicios equivalentes.

El artículo 17 del RGPD establece que el interesado tendrá derecho a obtener sin dilación indebida del responsable del tratamiento la supresión de los datos personales que le conciernan, el cual estará obligado a suprimir sin dilación indebida los datos personales cuando concurra alguna de las circunstancias siguientes:

1. Los datos personales ya no sean necesarios en relación con los fines para los que fueron recogidos o tratados de otro modo.
2. El interesado retire el consentimiento en que se basa el tratamiento de conformidad, y este no se base en otro fundamento jurídico.
3. El interesado se oponga al tratamiento y no prevalezcan otros motivos legítimos para el tratamiento.
4. Los datos personales hayan sido tratados ilícitamente.
5. Los datos personales deban suprimirse para el cumplimiento de una obligación legal.
6. Los datos personales se hayan obtenido en relación con la oferta de servicios de la sociedad de la información mencionados en el artículo 8 del RGPD en su apartado 1.

Cuando el responsable del tratamiento este obligado a suprimir los datos, lo hará teniendo en cuenta la tecnología disponible y el coste de su aplicación adoptando las medidas razonables, incluidas medidas técnicas.

La supresión además de a los datos, deberá incluir la supresión de cualquier enlace a esos datos personales, y copia o réplica de estos.

La guía [CCN-STIC 105](#) publicada por el CCN y actualizada en julio de 2022, de título Catálogo de Productos y Servicios de Seguridad de las TIC tiene por objeto ofrecer a los organismos de la Administración un conjunto de productos o servicios STIC de referencia cuyas funcionalidades de seguridad relacionadas han sido evaluadas y certificadas, y cumplen con los requisitos de seguridad mínimos establecidos por el CCN.

Esta guía ofrece en su sección “Productos y servicios cualificados”, dedicada a los requisitos de seguridad exigidos para el manejo de información sensible en relación, con el derecho de supresión en su apartado 7.5.3 relativo a la familia de productos de borrado seguro, las siguientes herramientas de borrado seguro de archivos y discos

1. Blancco Drive Eraser.
2. Blancco File Eraser.
3. Olvido Windows.

En relación a la destrucción y eliminación de documentos se debe aplicar las indicaciones establecidas en la Política de Gestión de Documentos Electrónicos del MINHAP en su apartado “2.5.9 Destrucción o eliminación”, y que se encuentran detallados en la [Guía de aplicación de la eliminación](#).

La eliminación de los documentos únicamente podrá realizarse una vez la Comisión Superior Calificadora de Documentos Administrativos (CSCDA) haya emitido el correspondiente dictamen, en

base a la calificación previa de la serie documental a la que pertenece y superados los plazos establecidos en el calendario de conservación.

A continuación, se muestra un gráfico con el proceso completo a seguir por las organizaciones.

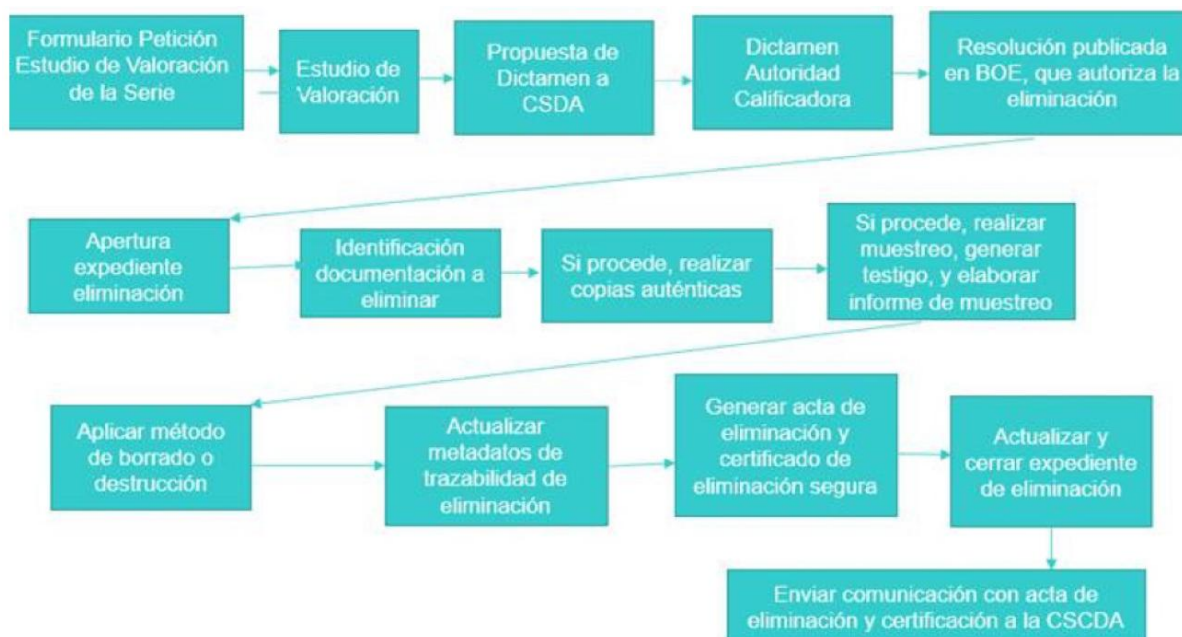


Ilustración 16. Proceso de eliminación en la política de gestión de documentos electrónicos. Fuente: página web de Administración electrónica

El procedimiento que se siga para la eliminación, borrado o destrucción de los documentos electrónicos deberá realizarse prestando especial atención cuando estos incluyen datos personales, de forma que el proceso en sí no suponga un riesgo de seguridad y vulnere la confidencialidad y que este produzca con su ejecución los resultados completos de supresión.

La diferencia técnica entre los términos en esta materia podría resumirse como sigue:

1. Borrado: es la operación de eliminación del fichero correspondiente a un documento electrónico, es decir marcar como libre el espacio que ocupa en el soporte de almacenamiento (borrado de nivel 0).
2. Borrado seguro: es aquel en el que el procedimiento se basa en técnicas de sobrescritura, desmagnetización, etc., de manera que sea imposible recuperar la información que contenían (en función del nivel de exhaustividad necesario, será un borrado de nivel 1 o de nivel 2, y determinará, por ejemplo, si el soporte será destruido o reutilizado después)
3. Destrucción: consiste en la destrucción física de un soporte de almacenamiento que ha contenido documentos electrónicos para impedir su reutilización.
4. Eliminación segura: es el proceso que incluye las técnicas de borrado y destrucción seguros, y la verificación de sus resultados.

ADAPTACIÓN DE APLICACIONES Y ENTORNOS A LOS REQUISITOS DE LA NORMATIVA DE PROTECCIÓN DE DATOS SEGÚN LOS NIVELES DE SEGURIDAD

En todo caso, deberá asegurarse la trazabilidad del procedimiento seguido en el borrado o destrucción.

La exhaustividad del proceso de eliminación vendrá determinada por el nivel de protección de la información en base a la dimensión confidencialidad del ENS y la existencia de datos personales o categorías especiales de datos personales.

Las técnicas de borrado y destrucción segura de soportes son las siguientes:

1. Borrado de nivel 0 (indicando otras medidas de seguridad como control de accesos o cifrado)
2. Borrado seguro de nivel 1
 - 2.1. Sobrescritura (de 3 pasadas)
3. Borrado de nivel 2:
 - 3.1. Sobrescritura (de 4 o más pasadas, aunque lo habitual serían 7).
 - 3.2. Comandos a nivel de firmware.
 - 3.3. Borrado criptográfico
 - 3.4. Desmagnetización.
4. Destrucción segura de soportes:
 - 4.1. Trituración.
 - 4.2. Desintegración.
 - 4.3. Aplastamiento.
 - 4.4. Pulverización.

La elección del proceso de eliminación puede realizarse con la siguiente tabla:

PROCESO DE ELIMINACIÓN							
MOTIVO DE LA ELIMINACIÓN	CONTEXTO DE LOS SOPORTES	TIPO DE GESTIÓN	AFECTA A LA TOTALIDAD DEL SOPORTE	REAPROVECHAMIENTO DEL SOPORTE	NIVEL DE PROTECCIÓN DE LA INFORMACIÓN	ACCIONES RECOMENDADAS	NOTAS
EJECUCIÓN DE UN DICTAMEN DE ELIMINACIÓN --- TRANSFERENCIA A ARCHIVO --- CAMBIO DE SOPORTE	SISTEMA DE ALMACENAMIENTO	GESTIÓN INTERNA	SÍ	SÍ	APLICA RGPD NIVEL MEDIO / ALTO ENS	BORRADO SEGURO NIVEL 1 BORRADO SEGURO NIVEL 2	(1)
				NO		DESTRUCCIÓN SEGURA DE SOPORTES	
			NO	SÍ	NO APLICA RGPD NIVEL BAJO ENS	BORRADO SEGURO NIVEL 1	
				NO		DESTRUCCIÓN SEGURA DE SOPORTES	
		GESTIÓN EXTERNA	NO	SÍ	APLICA RGPD NIVEL MEDIO / ALTO ENS	BORRADO NIVEL 0	(2)
				NO	NO APLICA RGPD NIVEL BAJO ENS	BORRADO NIVEL 0	(2)
			SÍ	SÍ	APLICA RGPD NIVEL MEDIO / ALTO ENS	BORRADO SEGURO NIVEL 2	(3)
				NO		DESTRUCCIÓN SEGURA DE SOPORTES	
				SÍ	NO APLICA RGPD NIVEL BAJO ENS	BORRADO SEGURO NIVEL 1 BORRADO SEGURO NIVEL 2	(4)
				NO		DESTRUCCIÓN SEGURA DE SOPORTES	
			NO	SÍ	APLICA RGPD NIVEL MEDIO / ALTO ENS	BORRADO NIVEL 0	(5)
				NO	NO APLICA RGPD NIVEL BAJO ENS	BORRADO NIVEL 0	(5)

Ilustración 17. Elección del proceso de eliminación en la política de gestión de documentos electrónicos. Fuente: página web de Administración electrónica

Fuente: POLÍTICA DE GESTIÓN DE DOCUMENTOS ELECTRÓNICOS (3ª EDICIÓN). 9. Guía de aplicación de eliminación

Se transcriben a continuación las notas de la anterior tabla tomadas de la guía:

- 1. Según el nivel de protección de la información podría aplicarse un borrado seguro de nivel 1 o 2.*
- 2. El borrado de nivel 0 debería combinarse con un control de accesos.*
- 3. Al ser externa la gestión de los soportes de almacenamiento, lo recomendable sería aplicar un borrado seguro de nivel 2.*
- 4. Aunque el nivel de protección de la información sea básico, la gestión externa de los soportes haría recomendable escoger entre un borrado seguro de nivel 1 o 2.*
- 5. El borrado de nivel 0 debería combinarse con un control de accesos y, al tratarse de una gestión externa de los soportes, sería recomendable asimismo añadir alguna otra medida de seguridad, como por ejemplo el cifrado de la información.*

A continuación, se indican los métodos y técnicas compatibles con cada tipo de soporte:

SOPORTES DE ALMACENAMIENTO Y MÉTODOS Y TÉCNICAS DE BORRADO Y DESTRUCCIÓN						
SOPORTES DE ALMACENAMIENTO						
	HDD	CINTA MAGNÉTICA	DISCO ÓPTICO WORM	DISCO ÓPTICO REGRABABLE	SSD	
BORRADO (NIVEL 0) + CONTROL DE ACCESOS (+ cifrado)						
BORRADO (NIVEL 0)	X	X		X	X	
BORRADO SEGURO - NIVEL 1						
SOBREESCRITURA (=3)	X				X	
BORRADO SEGURO - NIVEL 2						
SOBREESCRITURA (>=4)	X				X	
COMANDO A NIVEL DE FIRMWARE	X				X	
BORRADO CRIPTOGRÁFICO	X				X	
DESMAGNETIZACIÓN	X	X				
DESTRUCCIÓN SEGURA DE SOPORTES						
TRITURACIÓN			X	X		
DESINTEGRACIÓN		X			X	
APLASTAMIENTO	X				X	
PULVERIZACIÓN	X					

Ilustración 18. Métodos y técnicas compatibles con cada soporte. Fuente: POLÍTICA DE GESTIÓN DE DOCUMENTOS ELECTRÓNICOS (3ª EDICIÓN). 9. Guía de aplicación de eliminación

3.6 RESPUESTA A INCIDENTES Y NOTIFICACIÓN DE BRECHAS DE SEGURIDAD

La guía de *Gestión del riesgo y evaluación de impacto en tratamientos de datos personales* recomienda el siguiente conjunto de controles en relación con la gestión de incidentes:

1. Definir planes de contingencia ante una brecha de datos personales.
2. Establecer los medios técnicos necesarios para la detección automática de brechas de datos personales.
3. Implantar las necesarias herramientas de gestión de incidentes adaptadas a los requisitos del RGPD.
4. Definir protocolos para la identificación de potenciales brechas en las quejas o comunicaciones de los usuarios o interesados.

5. Comprobar la capacidad de evaluar la gravedad de las brechas.
6. Establecer procedimientos para describir con precisión el impacto de una brecha para los derechos y libertades.
7. Definir canales internos ágiles para dar respuesta a los incidentes.

En los aspectos relativos a la monitorización y supervisión, el ENS en su artículo 24 establece que se debe documentar las actividades permitiendo registrar en cada momento a la persona que actúa, por lo que es importante que cada usuario esté identificado de forma unívoca en las aplicaciones.

Además, velando por lo establecido por el Reglamento General de Protección de Datos y el respeto a los principios de limitación de la finalidad, minimización de los datos y limitación del plazo de conservación, se podrán analizar las comunicaciones entrantes o salientes únicamente para los fines de seguridad de la información.

Para dar respuesta a la necesaria monitorización para la detección de incidentes, se recomienda la instalación de los sistemas de alerta temprana SAT-Inet y SAT-SARA, o SAT-ICS en el caso de sistemas de control industrial. Los sistemas de alerta temprana permiten la detección rápida de incidentes y anomalías dentro de la Administración y de las empresas de interés estratégico, mediante la consulta en tiempo real de los eventos de seguridad capacitando la ejecución acciones preventivas, correctivas y de contención.

Además, es necesario utilizar sistemas de gestión de información y eventos de seguridad (SIEM de sus siglas, *Security Information and Event Management*) del CCN-CERT. Tres herramientas del CCN interesantes en este ámbito son:

1. GLORIA es un gestor de eventos (logs) para responder ante incidentes y amenazas
2. CARMEN/CLAUDIA, herramientas de detección de amenazas avanzadas (APT) basada en comportamientos anómalos.
3. MONICA es un sistema automatizado de gestión de información y eventos de seguridad.

Los SIEM en general, ofrecen la monitorización de la seguridad y permitirán en conjunto anticiparse ante ataques dirigidos, la detección de fugas de información, el robo de credenciales y los ataques de reputación. Entrando en mayor detalle, permitirán:

1. Alertar de las vulnerabilidades emergentes identificadas por los sistemas de prevención.
2. Facilitar la monitorización y la recogida de logs por las consolas de servicio que permitan la identificación de conductas sospechosas, reconfiguración de las alertas establecidas, definición de nuevas alertas, correcciones en la recogida de logs, etc.
3. Establecer procesos periódicos de revisión de los logs generados para identificar riesgos y comportamientos anómalos para su posterior análisis. La periodicidad podrá ser diaria o mensual en función de criticidad.
4. Facilitar la detección de falsos positivos o negativos analizando las alertas detectadas.

5. Procesar y correlar los eventos recolectados en tiempo real para detectar sucesos relevantes en la infraestructura gestionada que puedan ser indicativas de un ataque y emitir las alertas oportunas.

En el caso de producirse un incidente, deberá ajustarse a lo establecido por la Instrucción Técnica publicada por [Resolución de 13 de abril de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Notificación de Incidentes de Seguridad](#).

Es importante destacar que esta instrucción reconoce y establece el régimen legal de las notificaciones y la comunicación de información que se solicite en los análisis de los incidentes, atendiendo a que está comunicación se realizaría para el cumplimiento de fines directamente relacionados con la función legítima de las entidades cedentes y del CCN como cesionario, sin que sea preciso el consentimiento del afectado toda vez que tales datos han sido recabados para el ejercicio de las funciones propias de unos y otro, y por la afectación a la Ciberseguridad, como ámbito de especial interés para la Seguridad Nacional.

Esta instrucción referencia al uso de la herramienta LUCIA (Listado Unificado de Coordinación de Incidentes y Amenazas) que proporciona una clasificación del incidente, mantiene la trazabilidad y el seguimiento del mismo y centraliza la notificación de incidentes de seguridad y su gestión

Además del seguir la Instrucción Técnica de Notificación de Incidentes de forma general dentro del ámbito de la seguridad de la información, el artículo 33 del RGPD impone a los responsables de un tratamiento de datos personales la obligación de notificar en el plazo de 72 horas a la AEPD las brechas de datos personales cuando sea probable que constituyan un riesgo para los derechos y libertades de las personas, además, si el riesgo es alto se debe comunicar la brecha a las personas afectadas conforme al artículo 34 del RGPD.

Para dar respuesta a la obligación de notificación de brechas a la AEPD esta ha publicado en su web el acceso a la herramienta [Comunica Brecha RGPD](#), esta herramienta permite valorar la obligación de informar a las personas físicas afectadas por una brecha de seguridad de los datos personales, tal y como establece el artículo 34 del RGPD.

Las notificaciones de brechas de datos personales a la AEPD se deben realizar de forma electrónica, usando el formulario de notificación de brechas de datos personales de la Sede Electrónica. La lista de acciones a realizar desde la sede electrónica. Puede consultarse mayor detalle sobre esta comunicación en: <https://www.aepd.es/es/derechos-y-deberes/cumple-tus-deberes/medidas-de-cumplimiento/brechas-de-datos-personales-notificacion>.

The screenshot shows the 'Comunica Brecha RGD' (Report Data Breach) tool from the AEPD (Agencia Española de Protección de Datos). The interface is in Spanish and features a navigation bar with icons for 'Inicio Instrucciones', 'Sector Actividad', 'Sobre la Brecha' (highlighted), 'Sobre las Consecuencias', 'Categorías de Datos', 'Personas Afectadas', 'Información Temporal', and 'Obligación Comunicar'. The main content area is titled 'Sobre la brecha de seguridad de los datos personales'. It contains two sections for reporting the incident: 'El incidente ha sido: *' and 'El origen del incidente ha sido: *'. The first section has three radio button options: 'Accidental o sin intencionalidad', 'Intencionado', and 'Desconocido'. The second section has three radio button options: 'Interno: Personal o sistemas del responsable de tratamiento', 'Interno: Personal o sistemas del encargado de tratamiento', and 'Externo: Otros, ajenos al responsable y encargado de tratamiento'. Below these sections is a question: '¿La brecha de seguridad es consecuencia de un ciberincidente?: *' with two radio button options: 'Si' and 'No'. At the bottom of the form are two orange buttons: 'Anterior' and 'Siguiente'.

Ilustración 19. Herramienta Comunica Brecha RGD. Fuente: página web de la AEPD

3.7 CONCLUSIÓN

Para determinar las medidas a implantar para la adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos, se han tenido en cuenta los principios, obligaciones, actividades, procesos y medidas relativas a la protección de los datos personales como garantía a los derechos y libertades establecidas en el RGPD y la LOPDGD, así como los requisitos establecidos para las medidas organizativas, de proceso y técnicas enumeradas en el Anexo II del ENS.

4 HERRAMIENTAS DE CIFRADO Y AUDITORÍA

4.1 INTRODUCCIÓN

El presente punto de este tema en relación con las herramientas de cifrado no pretende hacer un desarrollo completo de los algoritmos de cifrado que son tratados explícitamente en el tema 79, sino ajustarse a su relación con la normativa de protección de datos personales.

Este apartado de este tema en relación con las auditorías no pretende hacer un desarrollo completo de la disciplina de la auditoría informática tratada explícitamente en el tema 38, sino ajustarse a su relación con la normativa de protección de datos personales.

El RGPD establece el cifrado y la seudonimización como técnicas fundamentales en la mitigación del riesgo en relación con la protección de datos personales para garantizar la privacidad de las comunicaciones y de los datos.

Los requisitos del cifrado son establecidos en el Anexo II del ENS y los aspectos a tener en cuenta en la implantación son establecidos la guía CCN-STIC 804 de Implantación del ENS.

En relación con la auditoría, aunque el RGPD y la LOPDDGG no menciona explícitamente este concepto, si se extiende en relación con la actividad de supervisión y vigilancia, lo que puede derivarse en el concepto de auditoría.

En relación con la auditoría se puede cumplir con establecido en el ENS y la Instrucción Técnica de Seguridad de Auditoría publicada al respecto y en relación con aspectos de cumplimiento normativo en protección de datos lo establecido en la guía de evaluación de impacto.

4.2 HERRAMIENTAS DE CIFRADO

4.2.1 NORMATIVA Y MARCO JURÍDICO APLICABLE

El RGPD hace especial mención al cifrado y la seudonimización en su considerando 83 y artículos 6 y 32.

Considerando 83:

“A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a

los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales.”

Artículo 6, apartado 4:

“Cuando el tratamiento para otro fin distinto de aquel para el que se recogieron los datos personales no esté basado en el consentimiento del interesado o en el Derecho de la Unión o de los Estados miembros que constituya una medida necesaria y proporcional en una sociedad democrática para salvaguardar los objetivos indicados en el artículo 23, apartado 1, el responsable del tratamiento, con objeto de determinar si el tratamiento con otro fin es compatible con el fin para el cual se recogieron inicialmente los datos personales, tendrá en cuenta, entre otras cosas:

...

e) la existencia de garantías adecuadas, que podrán incluir el cifrado o la seudonimización.”

Artículo 32, apartado 1:

“Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

a) la seudonimización y el cifrado de datos personales”

Artículo 34, apartado 3

“La comunicación al interesado a que se refiere el apartado 1 no será necesaria si se cumple alguna de las condiciones siguientes:

a) el responsable del tratamiento ha adoptado medidas de protección técnicas y organizativas apropiadas y estas medidas se han aplicado a los datos personales afectados por la violación de la seguridad de los datos personales, en particular aquellas que hagan ininteligibles los datos personales para cualquier persona que no esté autorizada a acceder a ellos, como el cifrado.”

El Grupo de Trabajo 29 publicó en 2018 una [Declaración sobre el cifrado y su impacto en la protección de los individuos con respecto a la protección de sus datos personales en la Unión Europea](#), según la cual:

Se considera el cifrado como un elemento capital para garantizar la privacidad de las comunicaciones y defiende la necesidad de implementar sistemas de cifrado robustos, eficientes y estandarizados para la protección de la privacidad de los ciudadanos europeos.

La Declaración establece el cifrado como un elemento necesario e irremplazable para garantizar la privacidad de la comunicación en Internet y que dicha protección ha de implementarse de extremo a extremo, es decir, directamente entre los usuarios finales sin elementos intermedios que tengan acceso a la información.

Dichos sistemas no pueden tener limitaciones en su rendimiento con el propósito de permitir la supervisión de las comunicaciones por las autoridades policiales o judiciales. La necesidad de levantar el velo de las comunicaciones para la investigación de actividades criminales no justifica la incorporación de vulnerabilidades secretas en los sistemas de cifrado, como claves maestras o puertas traseras.

Por último, del dictamen que este mismo grupo de trabajo había publicado en el año 2014 que lleva por título [Dictamen 05/2014 sobre técnicas de anonimización del Grupo del Artículo 29](#) que establece los límites del cifrado con relación a los datos de carácter personal indicando:

“Las técnicas de seudonimización más utilizadas son las siguientes:

- Cifrado con clave secreta:

...

Ni el cifrado ni la codificación con clave sirven en sí mismos para que un interesado no pueda ser identificado, ya que aún se puede acceder a los datos originales o deducirlos, al menos si están en manos del responsable del tratamiento...

Es engañoso fiarse exclusivamente de la solidez del mecanismo de cifrado como medida del grado de anonimización de un conjunto de datos, ...”

En definitiva, el cifrado se considera una medida técnica fundamental en la mitigación del riesgo en relación con la protección de datos personales para garantizar la privacidad de las comunicaciones y de los datos almacenados. Además, el responsable para determinar si es compatible el tratamiento con otro fin distinto para el que se recogieron los datos tendrá en cuenta, entre otros aspectos, la existencia de garantías adecuadas que podrían incluir el cifrado y la seudonimización.

En el caso de producirse una violación de la seguridad o acceso no autorizado, el cifrado exime de la obligación de comunicación de la brecha de seguridad a los afectados.

En todo caso, el cifrado no debe de servir de excusa para limitar las investigaciones policiales y judiciales.

4.2.2 ALGORITMO DE CIFRADO

El cifrado es la aplicación de un algoritmo que produce que la información pase a un estado ilegible limitando el acceso no autorizado a información confidencial.

El proceso de cifrado aplicado de una forma masiva puede resultar costoso en términos de cómputo, y limitar la agilidad de procesos de negocio, sin ofrecer un valor añadido necesario, es por esto por lo que se considera que es un proceso que se debe ajustar a los datos sensibles tratados por la organización y en el ámbito de los datos personales a los pertenecientes a categorías especiales establecidas en el Art. 9 del RGPD:

1. Origen étnico o racial.
2. Opiniones políticas.
3. Convicciones religiosas o filosóficas.
4. Afiliación sindical.
5. Datos genéticos.
6. Datos biométricos dirigidos a identificar de manera unívoca a una persona física.
7. Datos relativos a la salud.
8. Datos relativos a la vida sexual o las orientaciones sexuales de una persona física.

En todo caso, es muy importante destacar que la información cifrada no deja de tener naturaleza de dato de carácter personal, y en caso de que eventualmente alguien accediese a estos datos sería objeto de una sanción por revelación de datos de carácter personal sin consentimiento.

Para conocer qué algoritmos se consideran robustos hay que recordar que el factor de trabajo, considerando este como la cantidad de trabajo para romper un sistema criptológico, solamente es válido para un periodo de tiempo determinado, ya que se debe tener en cuenta cómo avanza la tecnología y la capacidad de procesamiento.

4.2.3 APLICACIÓN DEL CIFRADO

Para determinar el método de cifrado a utilizar se debe tener en cuenta si la información a cifrar se encuentra almacenada o si se necesita en la transmisión de datos, así como los requisitos de rendimiento, coste, recursos necesarios, etc.

En la transmisión de datos vía web será necesario utilizar el protocolo:

5. HTTPS, actualmente en su versión 3, que permite el cifrado de las comunicaciones extremo a extremo utilizando certificados reconocidos por una autoridad de confianza.

6. TLSv1.2 o superior que proporciona confidencialidad e integridad en las comunicaciones, y autenticidad al permitir confirmar que se accede al servidor indicado en la barra de direcciones del navegador.
7. Protocolos de cifrado para redes WIFI como WPA2-AES.

Cuando los datos se transmitan por email, se deberán cifrar con la clave pública del receptor, por ejemplo, el SW/programa *Pretty Good Privacy* (PGP) para clientes pesados o la extensión *Mailvelope* para navegadores web, teniendo en cuenta que se debe transmitir la contraseña por un medio distinto a la información cifrada, por ejemplo, mediante una llamada telefónica.

El cifrado de datos puede realizarse a nivel total o parcial del dispositivo, de forma nativa en las propias bases de datos, o con el uso de un módulo de seguridad hardware (HSM)

4.2.4 PRODUCTOS CUALIFICADOS

La guía CCN-STIC 105 que incorpora el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y la Comunicación, conocido como CPSTIC, presenta en su sección *Productos Cualificados* las familias de redes virtuales privadas y comunicaciones móviles seguras de la categoría de Protección de las Comunicaciones, y en particular en la categoría de Protección de la información y soportes de la información, las familias:

1. Cifradores IP
 - 1.1. EP430TX, EP960, EP430GX, EP430GX, EP430GN y EP430TX de Eplicom, IS101 de Istria Soluciones de Criptografía.
2. Almacenamiento cifrado de datos
 - 2.1. Cryhod para el cifrado de los discos duros de las estaciones de trabajo portátiles de la organización
3. Cifrado offline
 - 3.1. EP851, EP852 y EP880 de Epicom.
4. Hardware Security Module (HSM).
 - 4.1. Thales Luna K7 Cryptographic Module
 - 4.2. nShield Solo XC Hardware Security Module.
5. Sistemas para prevención de fugas de datos
 - 5.1. McAfee Data Loss Prevention (DLP) Endpoint with ePolicy Orchestrator 5.10.
 - 5.2. Forcepoint On-Premise Security 8.5.
6. Protección de correo electrónico
 - 6.1. FortiMail Appliances FML-200F, FML-400F, FML-900F, FML-VM

4.2.5 LISTADO DE MECANISMOS CRIPTOGRÁFICOS AUTORIZADOS

El CCN-CERT establece en su Guía CCN-STIC 807 de Criptología de Empleo en el Esquema Nacional de Seguridad, los mecanismos criptográficos que han sido autorizados para su uso en el ENS.

En esta guía se pueden consultar los principales mecanismos de cifrado clasificados en dos grupos:

1. Recomendados (R).
2. Heredados (L, sigla de *Legacy*), que tiene una garantía limitada por estar obsoletos y que deberán ser sustituidos antes del 31 de diciembre de 2025.

A continuación, se enumeran los principales mecanismos criptográficos:

1. Dentro del cifrado simétrico, que se fundamenta en clave privada y cifradores de bloque, quedan autorizados y recomendados los basados en el algoritmo AES con una longitud de clave de 128, 192 o 256 bits. En el caso de cifrado de discos duros se acepta también AES-XTS. En todo caso, deberán utilizarse con un mecanismo de autenticación.
2. El cifrado asimétrico está basado en una pareja de claves pública utilizada por los remitentes para cifrar la información a un destinatario y una clave privada que utilizará ese destinatario para descifrar esa información. Este cifrado se utiliza, por ejemplo, en el cifrado de la clave que será utilizada en el cifrado simétrico (transporte de clave). Las primitivas autorizadas son:
 - 2.1. RSA, basado en la factorización de números enteros. Está recomendada la longitud de clave mayor o igual de 3000 bits, y se considera *Legacy* la longitud de clave de 2048.
 - 2.2. MODP, basado en el problema del logaritmo discreto multiplicativo. Recomendado con longitudes de clave mayor de 8192 bits, y *Legacy* con 2048 bits.
 - 2.3. Curvas elípticas acordadas, como variantes del cifrado asimétrico basada en logaritmos discretos y que ofrece mejor rendimiento con claves más cortas. Están autorizadas las familias Brainpool, la publicada por NIST y Bernstein. No todas las curvas son aceptadas para el cifrado por lo que en una implementación debe consultarse la especificación.
3. La firma electrónica para garantizar la integridad, autenticidad de origen y el no repudio.
4. Los esquemas MAC para garantizar la integridad y autenticidad del origen.
5. El protocolo TLS para la protección de las comunicaciones, se autoriza y se recomienda las versiones 1.2 y 1.3.
6. El protocolo SSH autorizada en su versión SSHv2, para la administración remota de los sistemas.
7. El protocolo IPsec para el establecimiento de VPN's redes virtuales privadas seguras a través de redes IP no seguras.

4.2.6 LA CLAVE PÚBLICA COMO DATO PERSONAL

En relación con la clave pública de la criptografía asimétrica, la AEPD, en la misma línea que el Parlamento Europeo, ha considerado que tiene naturaleza de dato personal en base al artículo 4 y considerando 30 del RGPD.

Considerando 30:

Las personas físicas pueden ser asociadas a identificadores en línea facilitados por sus dispositivos, aplicaciones, herramientas y protocolos, como direcciones de los protocolos de internet, identificadores de sesión en forma de «cookies» u otros identificadores, como etiquetas de identificación por radiofrecuencia. Esto puede dejar huellas que, en particular, al ser combinadas con identificadores únicos y otros datos recibidos por los servidores, pueden ser utilizadas para elaborar perfiles de las personas físicas e identificarlas.

Artículo 4:

Toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.

El carácter unívoco de la clave pública y la asociación de información adicional que permita identificar a la persona (por ejemplo, para la identificación en línea como con las cookies, direcciones de correo, dirección IP, datos de sesión...), motiva considerarla como seudónimo con la consideración de dato personal, debido a que la clave pública y toda la información identificable en línea puede permitir la realización de un perfil e incluso la identificación de la persona física.

4.3 AUDITORÍA

4.3.1 NORMATIVA

Aunque ni el RGPD ni la LOPDDGG hacen referencia explícita a las auditorías de protección de datos, quedando exclusivamente definidos los planes de auditorías de la autoridad de control desde una perspectiva más general, sí que el RGPD recoge las medidas que deben cumplirse y que, en caso contrario, podrían suponer una sanción incluso si no existe daño consumado a los derechos y libertades de las personas físicas, es decir como fruto de una revisión, de lo que puede suponerse el concepto de auditoría.

En cuanto a las normas corporativas vinculantes, especificarán los mecanismos establecidos dentro del grupo empresarial o de la unión de empresas dedicada a una actividad económica conjunta para garantizar la verificación del cumplimiento de las normas corporativas vinculantes. Dichos mecanismos incluirán auditorías de protección de datos y métodos para garantizar acciones correctivas para proteger los derechos del interesado. (Artículo 47.2.j).

Según establece el artículo 39 del RGPD es función del Delegado de Protección de Datos la supervisión de su cumplimiento, la auditoría junto con la asignación de responsabilidades, la concienciación y formación del personal que participa en las operaciones de tratamiento.

A su vez, el artículo 28 del RGPD establece que el encargado del tratamiento pondrá a disposición del responsable toda la información necesaria para demostrar el cumplimiento de sus obligaciones y permitir y contribuir a la realización de auditorías, incluidas inspecciones, por parte del responsable o de otro auditor autorizado por dicho responsable.

Según la LOPDGDD, *"La AEPD desarrollará su actividad de investigación a través de las actuaciones previstas en el Título VIII y de los planes de auditoría preventivos. (Artículo 51)"*.

La Presidencia de la AEPD podrá acordar la realización de planes de auditoría preventiva, referidos a los tratamientos de un sector concreto de actividad. Tendrán por objeto el análisis del cumplimiento de las disposiciones del RGPD y de la LOPDGDD, a partir de la realización de actividades de investigación entidades pertenecientes al sector inspeccionado o sobre los responsables objeto de la auditoría. (Artículo 54).

A resultados de los planes de auditoría, la Presidencia de la AEPD podrá dictar las directrices generales o específicas para un concreto responsable o encargado de los tratamientos precisas para asegurar la plena adaptación del sector o responsable al RGPD y a la LOPDGDD. (Artículo 54)"

La Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información publicada en 2018 establece en su Disposición adicional sobre los datos personales que, a partir del 25 de mayo de 2018, cuando el sistema auditado tenga por objeto o incluya el tratamiento de datos personales, se tendrá en cuenta el RGPD.

4.3.2 EL PROCESO DE AUDITORÍA

La auditoría es una actividad que requiere de amplia experiencia por parte del personal responsable de su ejecución. Anualmente se recomiendan las siguientes actividades de auditoría:

1. Auditoría interna cumplimiento ENS conforme a la Guía CCN-STIC 802.
2. Auditoría de seguridad de las aplicaciones utilizando una metodología como OWASP.
3. Auditoría de pentesting desde internet.
4. Auditoría de pentesting desde dentro de la LAN.
5. Auditoría de la configuración de redes.

6. Auditoría anual de puesto de usuario.
7. Auditoría de código fuente.
8. Auditoría de cumplimiento de las normas y procedimientos de seguridad, así como del control de evidencias.

Estas auditorías pueden establecerse como actividades independientes o en una auditoría global, en todo caso, deben establecerse dentro de un plan global y anual de auditorías, con el objetivo de no ocasionar impacto en el negocio y determinar el alcance de las pruebas de penetración, comunicación, etc.

Los dominios que se recomiendan se tengan en consideración en la realización con una auditoría de protección de datos son:

1. El modelo organizativo con una correcta definición de roles y funciones en materia de gestión de seguridad de la información para lo que se puede atender a lo establecido en la guía CCN-STIC 801 de Responsabilidades y Funciones del ENS.
2. El funcionamiento del delegado de protección de datos y del encargado de protección de datos, según lo establecido en el RGPD y la LOPDDGG. Además de la definición de los canales de comunicación internos y externos con el DPD.
3. La licitud de los tratamientos con la revisión de consentimientos, contratos, cláusulas informativas, la información incorporada en el pie de los correos electrónicos, la política de privacidad de la web y la transparencia en la información.
4. La correcta actuación en la gestión de derechos de protección de datos con la revisión de los procedimientos y su publicidad, los formularios de solicitud para los interesados y los canales de comunicación.
5. La aplicación de la privacidad desde el diseño, junto con la aplicación del principio de minimización de datos.
6. El correcto registro de actividades de tratamientos, la revisión de la finalidad, plazos de conservación y accesibilidad.
7. La existencia de un análisis de riesgos y de una evaluación de impacto de la protección de datos, así como de la metodología y procedimientos para llevarlos a cabo.
8. La existencia y seguimiento de un procedimiento de notificación de brechas que cumpla con lo establecido por la AEPD y el CCN, así como la evaluación del impacto de las brechas ocurridas y de las notificaciones realizadas a la Autoridad de Control, la revisión de los procesos de investigación y resolución, y en todo caso, la difusión del procedimiento a seguir en caso de producirse incidentes.
9. La correcta implantación de medidas de seguridad resultado de un plan de adecuación al ENS para los tratamientos sometidos a esta norma. Para los tratamientos no sometidos al ENS se recomienda no implantar un nivel menor al establecido en el Anexo II del ENS.

10. El mantenimiento de los registros suficientes para demostrar el cumplimiento de la norma, incluida la ejecución de sus controles periódicos.
11. La existencia de un plan de formación y de concienciación.
12. La correcta ejecución de las transferencias internacionales si se produjeran.
13. El correcto desarrollo de los acuerdos de corresponsabilidad en el tratamiento de datos personales.

Como se ha indicado, en el proceso de auditoría se puede tomar como base lo establecido en esa materia en el ENS por el que todos los organismos deben, al menos, superar una auditoría ordinaria cada dos años. En este sentido, con la actualización en 2022 del ENS, el CCN ha publicado en el portal del Esquema Nacional de Seguridad una actualización del documento en el que se explican los requisitos y condiciones acerca de las Auditorías de Certificación del ENS, la expedición de las correspondientes Certificaciones de Conformidad y las relativas a la Acreditación de ENAC tras la publicación del Real Decreto 311/2022.

Los organismos que tengan auditorías superadas y certificados de conformidad emitidos en base al anterior RD 3/2010 deberán haber sido renovados y evaluados respecto al RD 311/2022 antes del 5 de mayo de 2024. Bajo circunstancias excepcionales podrán extenderse la validez del certificado de conformidad hasta el 5 de mayo del 2026.

El artículo 31 del ENS establece que los sistemas de información deben ser objeto de una auditoría regular ordinaria que verifique el cumplimiento de los requerimientos del ENS, al menos cada dos años.

Además, con carácter extraordinario, deberá realizarse una auditoría cuando se produzcan modificaciones sustanciales en el sistema de información, que puedan repercutir en las medidas de seguridad requeridas. Si esta auditoría fuese completa, determinará para iniciar el cómputo de dos años para la realización de la siguiente auditoría regular ordinaria, en caso contrario y solo se hubiese revisado las modificaciones producidas en el sistema, no se verá alterada la fecha para el cálculo de los dos años en que deberá renovarse la certificación. El plazo de dos años puede extenderse tres meses bajo circunstancias excepcionales de fuerza mayor no imputables al titular de los sistemas de información.

Además, el artículo 38 establece que para que los sistemas de información de categoría media y alta puedan determinar su conformidad con el ENS precisaran de la superación de una auditoría de conformidad, sin perjuicio de la auditoría de la seguridad prevista en el artículo 31 que podrá servir asimismo para los fines de la certificación. Los sistemas de categoría BÁSICA solo requerirán de una autoevaluación para su declaración de la conformidad, sin perjuicio de que se puedan someter igualmente a una auditoría de certificación.

Tanto el procedimiento de autoevaluación como la auditoría de certificación se realizarán según lo dispuesto en el anexo I y III y en los términos que se determinen en la correspondiente Instrucción

Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información publicada en la Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública.

La mencionada instrucción hace especial anotación en relación con los datos personales en su disposición adicional, estableciendo que, a partir del 25 de mayo de 2018, cuando el sistema auditado tenga por objeto o incluya el tratamiento de datos personales, se tendrá en cuenta el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE. A partir de dicha fecha en todo momento se informará al Delegado de Protección de Datos en calidad de responsable de la supervisión del cumplimiento del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016.

Para facilitar la auditoría, la implantación de las medidas de seguridad del ENS y la verificación de su cumplimiento, el CCN ha publicado las siguientes guías:

1. Guía CCN-STIC 808 de verificación del cumplimiento del Esquema Nacional de Seguridad que puede ser utilizado como un *checklist* o lista de comprobación.
2. Guía CCN-STIC 802 de Auditoría.
3. CCN-STIC 804 Guía de Implantación del ENS, que debería haberse utilizado también en la implantación de las medidas determinadas en el plan de adecuación al ENS.

Previo a la realización de la auditoría se deberán haber definido el alcance, el objetivo y la metodología que se utilizará. En todo caso, para no incurrir en problemas de independencia de la entidad certificadora para los aspectos de conformidad se tendrá especial cuidado de no extenderse a la ejecución de actividades de consultoría, implantación o modificación de aplicaciones, elaboración de documentos o redacción de procedimientos o recomendaciones y análisis de productos.

En el informe de auditoría los hallazgos de no conformidad se clasificarán en los siguientes grados:

1. No conformidad menor ante la ausencia o el fallo en la implantación o mantenimiento de uno o más de los requisitos del ENS.
2. No conformidad mayor cuando se detecten “no conformidades menores” de cualquier precepto del Marco organizativo del ENS o en alguno de los subgrupos que integran el Marco operacional o las Medidas de protección (Planificación, Control de Accesos, Explotación, Servicios Externos, Continuidad del Servicio, Monitorización del Sistema, Protección de las Infraestructuras, Gestión del Personal, Protección de Equipos, Comunicaciones, Soportes de Información, Aplicaciones Informáticas, Información o Servicios) que, evaluadas en su conjunto, puedan implicar el incumplimiento del objetivo del Grupo o Subgrupo considerados.

El dictamen final de la auditoría será uno de los siguientes:

1. Favorable, cuando no se evidencie ninguna no conformidad ni mayor, ni menor.

2. Favorable con no conformidades, cuando se evidencie cualquier no conformidad, mayor o menor. En este caso, la entidad titular responsable del sistema de información deberá presentar, en el plazo de un mes, un plan de acciones correctivas a la entidad certificadora para su evaluación.
3. Desfavorable, cuando, por el número o la transcendencia de las no conformidades detectadas, no sea posible decidir sobre su resolución a través de un plan de acciones correctivas. En este caso se requerirá la realización de una auditoría extraordinaria que verifique la adopción de las medidas correctoras adecuadas.

4.3.3 BENEFICIOS DEL PROCESO DE AUDITORÍA

Los beneficios directos de la realización de una auditoría de protección de datos personales son:

1. La evaluación de los riesgos y verificación de si las medidas implantadas son suficientes para su mitigación.
2. El descubrimiento de nuevos riesgos.
3. La adaptación de nuevas medidas de seguridad.
4. Demostrar el cumplimiento de las medidas.
5. Ofrecer confianza.
6. La detección de medidas susceptibles de mejora.
7. El propio proceso iterativo de las auditorías como proceso de mejora continua.

4.3.4 CONTENIDO DEL INFORME DE AUDITORÍA

Siguiendo las recomendaciones establecidas en el punto V.7 de la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información, el informe de auditoría deberá contener la información adecuada y suficiente para facilitar y justificar la decisión de certificación, como mínimo:

1. Las áreas organizativas, módulos o funciones del sistema de información cubiertas por la auditoría, incluyendo los requisitos de certificación y las ubicaciones que fueron auditadas, las pistas de auditoría seguidas y las metodologías de auditoría utilizadas.
2. Los hallazgos identificados, tanto de conformidad como de no conformidad, incluyendo las observaciones.
3. Los detalles de las no conformidades identificadas que se justificarán mediante evidencias objetivas y su correspondencia con los requisitos del ENS u otros documentos requeridos para la certificación.
4. Los comentarios sobre la conformidad del sistema de gestión de seguridad de la Información del auditado con los requisitos de certificación, con una redacción clara de las no conformidades que hubieran podido evidenciarse, una referencia a la versión de la declaración de aplicabilidad, que incluya el nivel en cada dimensión para cada medida de seguridad del

ENS aplicable, así como cualquier comparación útil con los resultados de Auditorías de la Seguridad previas.

5. La categoría del sistema, con detalle del nivel de seguridad en cada una de las dimensiones recogidas en el ENS.
6. El grado de confianza en las revisiones de la Dirección y auditorías internas del auditado.
7. La conclusión o dictamen del Equipo de Auditoría sobre si el sistema de información del auditado debe ser certificado o no, con información que soporte esa conclusión.

Los informes elaborados, como resultado de las auditorías, deberán conservarse porque podrán ser requeridos por el CCN-CERT, en los términos previstos en el artículo 37 del ENS.

4.3.5 CONTRATACIÓN DE SERVICIOS DE AUDITORÍA

El CCN ha publicado la guía CCN-CERT IC-02/20 Guía para contratación de auditorías de certificación del ENS con el objeto de recoger las recomendaciones básicas para la contratación del servicio de auditorías de certificación del ENS en cumplimiento con la Ley 9/2017.

4.3.6 HERRAMIENTAS DE AYUDA A LA AUDITORÍA

4.3.6.1 ASSI-RGPD

ASSI-RGPD (Auditoría de Seguridad de los Sistemas de Información - Reglamento General de Protección de Datos) es una herramienta Desarrollado por el Ministerio de Trabajo, Migraciones y Seguridad Social, con su última versión publicada en 2019. Esta herramienta que fue muy destacada, no se encuentra actualmente disponible ni en el portal de la AEPD, ni en el Centro de Transferencia Tecnológica de la página de Administración Electrónica.

Puede consultarse una memoria descriptiva de esta herramienta todavía disponible en este enlace del [ASSI-RGPD](#).

Esta herramienta permitía mantener un Registro de Actividades de Tratamientos de Datos Personales (RAT), facilitar el cumplimiento de las obligaciones del RGPD y la LOPDGDD, realizar un análisis de riesgo, realizar una evaluación de impacto y un proceso de autoevaluación o auditoría. En cierta forma sus funciones pueden obtenerse a través de las herramientas de la AEPD enumeradas a lo largo de este tema.

4.3.6.2 GESTIONA

La herramienta gestion.aepd.es descrita en el apartado de Medidas de seguridad permite funcionalidad completa de análisis de riesgos, evaluación de impacto y de ayuda a la implantación de medidas.

GESTIONA EIPD

La Evaluación de Impacto en la Protección de Datos Personales (EIPD) es una herramienta que permite evaluar de manera anticipada cuáles son los potenciales riesgos a los que están expuestos los datos personales en función de las actividades de tratamiento que se llevan a cabo con los mismos. El análisis de riesgos para un determinado tratamiento permite identificar los riesgos que se ciernen sobre los datos de los interesados y establecer una respuesta adoptando las salvaguardas necesarias para reducirlos hasta un nivel de riesgo aceptable.

La EIPD es una herramienta con carácter preventivo que debe realizar el responsable del tratamiento para poder identificar, evaluar y gestionar los riesgos a los que están expuestas sus actividades de tratamiento con el objetivo de garantizar los derechos y libertades de las personas físicas. En la práctica, la EIPD permite determinar el nivel de riesgo que entraña un tratamiento, con el objetivo de establecer las medidas de control más adecuadas para reducir el mismo hasta un nivel considerado aceptable.

El resultado de la EIPD se debe tener en cuenta, necesariamente, a la hora de tomar las decisiones relacionadas con el cumplimiento de lo previsto en el RGPD y la toma de decisión de la viabilidad o no de llevar a cabo el tratamiento de los datos.

Una EIPD no se requiere siempre, en cada actividad de tratamiento, se debe valorar la necesidad de llevar a cabo la misma. Es fundamental realizar el siguiente análisis previo para determinar de forma preliminar el nivel de riesgo al que puede estar expuesto el tratamiento y tomar la decisión adecuada en base a ello.

Herramienta FACILITA ?

Iniciar nueva EIPD

Iniciar análisis de riesgos

Ilustración 20. Herramienta Gestiona. Fuente: <https://gestiona.aepd.es/>

4.3.6.3 PILAR

PILAR es un conjunto de herramientas de análisis de riesgos de sistemas de información en las dimensiones: confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad.

PILAR sigue la metodología Magerit v3, permite la verificación del RGPD y la integración con la herramienta INES para la aportación de información que, de forma agregada, es utilizada en la elaboración del Informe anual del Informe del Estado de la Seguridad.

Esta herramienta se encuentra disponible en tres versiones:

1. PILAR, como versión íntegra, disponible en dos versiones PILAR RM para análisis y gestión de riesgos, y PILAR BCM para el análisis de impacto y continuidad de operaciones
2. Pilar Basic, como versión sencilla para Pymes y Administración Local.
3. µPILAR, como versión reducida.

Además, CCN-CERT pone a disposición RMAT (*Risk Management Additional Tools*), una herramienta de personalización para ser utilizada por consultores y grandes organizaciones, y configurar de forma específica distintos perfiles de protección con criterios de evaluación/acreditación específicos de ciertos sectores, perfiles de amenazas en base a los diferentes entornos de operación, y detallar protecciones adicionales.



Ilustración 21. Herramientas PILAR. Fuente CCN <https://pilar.ccn-cert.cni.es/index.php/pilar/que-es-pilar>

PILAR ayuda a analizar los riesgos derivados del análisis de impacto de la protección de datos personales, ocupándose concretamente de los riesgos sobre derechos y libertades, y las medidas definidas para tratar dichos riesgos.

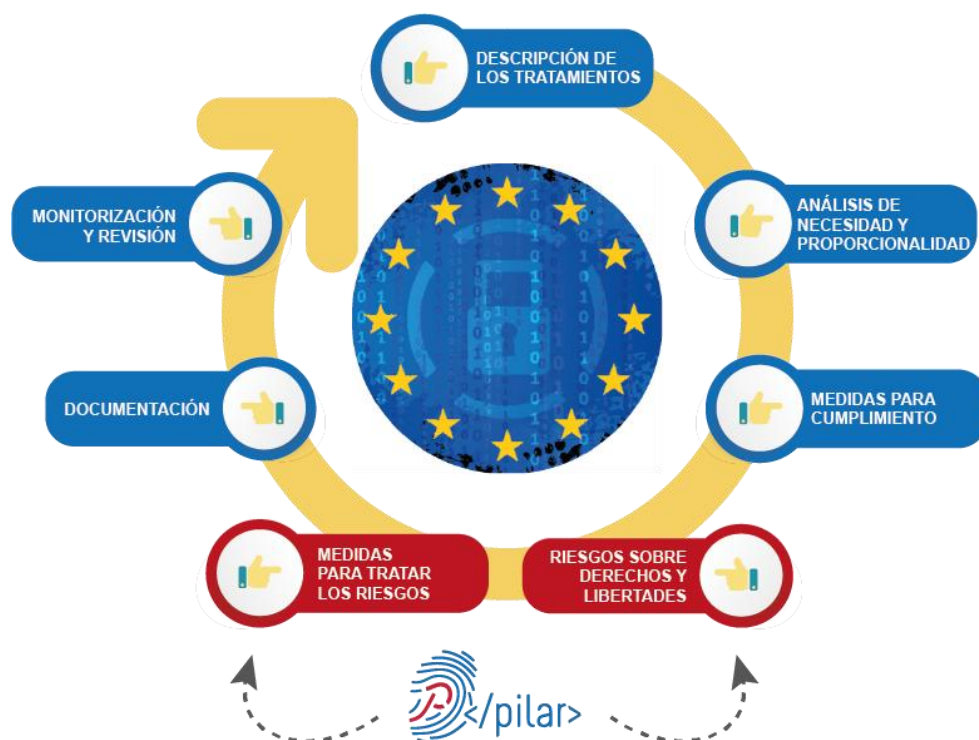


Ilustración 22. 'Funcionalidades del RGPD en herramienta PILAR Fuente <https://pilar.ccn-cert.cni.es/index.php/pilar/verificacion-rgpd>

4.3.6.4 AMPARO

El CCN pone a disposición de los organismos la herramienta AMPARO accesible toda su información en la URL <https://www.ccn-cert.cni.es/soluciones-seguridad/amparo.html> con la que es posible realizar la implantación y gestión de la seguridad, entre su funcionalidad se encuentra:

1. Un asistente para llevar a cabo la implantación de las medidas y evaluar la conformidad durante la implantación para detectar carencias y que puedan ser corregidas a tiempo.
2. El acceso a los modelos de procedimientos y normativas necesarios para la adecuación al ENS.

3. La gestión de la documentación del marco normativo.
4. La evaluación del sistema.
5. La obtención de la declaración de conformidad del sistema para categoría BÁSICA del ENS, o solicitar una Auditoría de Conformidad a una Entidad de Certificación acreditada.
6. En el caso de ser necesario una auditoría con una Entidad de Certificación acreditada, permite la comunicación con la misma y ver el estado del sistema.
7. La gestión de la seguridad del sistema, con el registro de usuarios, soportes, formación, etc.
8. En materia de privacidad, AMPARO permite identificar los tratamientos de datos que tiene el organismo y realizar el Análisis de Impacto relativo a la normativa de Protección de Datos.
9. La integración con las herramientas del CCN: ANA, ROCIO y CLARA.

A continuación, se muestra esquemáticamente la relación entre las soluciones INES y AMPARO:

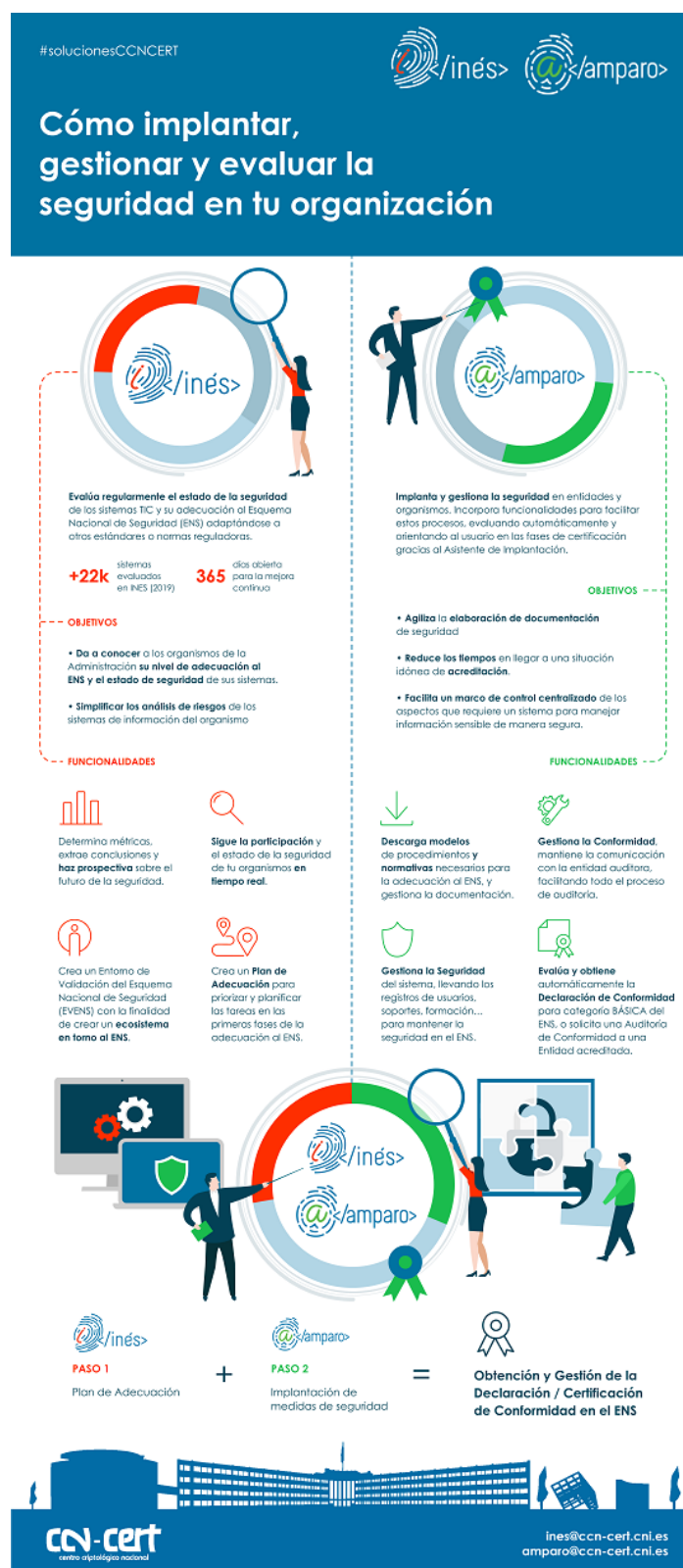


Ilustración 23. Implantación, gestión y evaluación de la seguridad con las soluciones INES y AMPARO del CCN.

Fuente www.ccn-cni.es (<https://www.ccn-cert.cni.es/soluciones-seguridad/amparo.html>)

4.3.7 AUDITORÍA E INTELIGENCIA ARTIFICIAL

En concreto en el ámbito de los tratamientos que incluyan técnicas de Inteligencia Artificial, la AEPD ha publicado una guía de *Requisitos para Auditorías de Tratamientos que incluyan IA*, como continuación a la que tiene por título *Adecuación al RGPD de tratamientos que incorporan Inteligencia Artificial* que presta especial atención a la seudonimización y anonimización, los perfilados o las decisiones automatizadas.

Esta guía es útil tanto para auditores, como para desarrolladores, y en ella se describen un conjunto de amenazas específicas de los componentes IA como, por ejemplo:

1. El acceso y manipulación a los datos de entrenamiento.
2. La inclusión de troyanos.
3. La manipulación de la API para habilitar accesos al modelo.
4. Los ataques basados en la provisión de información engañosa.
5. La imitación de patrones.
6. La reidentificación de datos personales.
7. El filtrado a terceros de resultados de perfilado o decisiones.

En todo caso la auditoría, por lo especial de estos casos deberá tener presente el contexto y el entorno de la solución IA que se emplea para el propósito para el que fue diseñada y en todo caso las auditorías técnicas de operación realizarlas de forma automática en tiempo real cuando su aplicación sea la toma de decisiones automatizadas para poder actuar antes de que se produzcan consecuencias graves.

4.4 CONCLUSIÓN

Para determinar el método de cifrado a utilizar se debe tener en cuenta si la información a cifrar se encuentra almacenada o si se necesita en la transmisión de datos, así como los requisitos de rendimiento, coste, recursos necesarios etc.

El Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y la Comunicación, conocido como CPSTIC, ofrece los productos cualificados y aceptados por el CCN para establecer las familias de redes virtuales privadas y comunicaciones móviles y herramientas para el cifrado.

Respecto al proceso de auditoría, el artículo 31 del ENS establece que los sistemas de información deben ser objeto de una auditoría regular ordinaria que verifique el cumplimiento de los requerimientos del ENS, al menos cada dos años. Para llevar a cabo esta auditoría debe cumplirse la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información publicada en la Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, así como lo

establecido en el análisis de riesgo según la normativa de protección de datos y la evaluación de impacto si, en función del riesgo, este es necesario.

5 ACTUALIDAD Y TENDENCIAS FUTURAS

En las XII Jornadas CCN-STIC celebradas el 12 y 13 de 2018 el Dr. Carlos Galán presentó el trabajo realizado para el análisis de la convergencia entre el ENS y el RGPD, este trabajo que se anticipa saldrá publicado en una guía de título *Impacto RGPD en el ENS*.

El número de la guía CCN-STIC indicado en la ponencia es el 881 cuyo número es actualmente utilizado por la guía de título *Adecuación al ENS para Universidades*. Cuando se publique la guía con el análisis de convergencia entre el ENS y el RGPD podrá descargarse desde la página web del CCN.

Con la publicación en el año 2022 de la actualización del ENS, la guía 804 de título *Implantación del ENS* es previsible que sea actualizada con la incorporación del concepto de *refuerzo* introducido en el Anexo II de la actualización del ENS.

6 RESUMEN ESQUEMÁTICO

Normativa y marco jurídico aplicable en los dos apartados de este tema:

1. Reglamento general de protección de datos
2. Ley Orgánica de Protección de Datos Personales y garantía de los derechos digitales.
3. El Esquema Nacional de Seguridad.

Adaptación de aplicaciones y entornos a los requisitos de la normativa de protección de datos según los niveles de seguridad

- Principios en el RGPD:
 1. Licitud.
 2. Finalidad.
 3. Minimización de datos.
 4. Exactitud.
 5. Limitación del plazo de conservación.
 6. Seguridad.
- Roles en la protección de datos:
 1. Responsable del tratamiento
 2. Encargado del tratamiento.
 3. Delegado de protección de datos.
- Tareas en la adaptación de aplicaciones y entornos:
 1. Realizar un análisis sobre la organización, la información y los sistemas.
 2. Nombrar un Delegado de Protección de Datos que deberá actuar dentro de una completa estructura orgánica de gestión de seguridad de la información.
 3. Elaborar el Registro de actividades de tratamiento (RAT) analizando y determinando las bases jurídicas de los tratamientos y su finalidad. Posteriormente, realizar su mantenimiento.
 4. Realizar un inventario y desarrollar los consentimientos y las cláusulas de derecho de información. Si estos ya existiesen, se deberán actualizar con las exigencias del RGPD.
 5. Llevar a cabo el análisis de riesgos que ayude a determinar la necesidad o no de realizar una evaluación de impacto.
 6. Si el análisis realizado en el anterior punto resulta de alto riesgo, se deberá realizar una Evaluación de Impacto conforme a las directrices del Grupo de Trabajo del Artículo 29.
 7. Elaborar un marco documental completo, comenzando con la Política de Seguridad de la Información y la Política de Protección de Datos, y continuando con el resto de los

procedimientos, entre ellos, el procedimiento de gestión de derechos de los titulares y registro de atención de derechos.

8. Llevar a cabo un plan de formación y concienciación en la seguridad de la información y la protección de datos.
 9. En la metodología que se implante en las organizaciones para poder llevar a cabo y mantener una correcta adecuación a la normativa de protección de datos, se debe tener en cuenta el seguimiento y control periódicos por parte de los responsables en seguridad de la información y en la protección de datos.
- Aplicar medidas en relación con:
 1. El deber de información ofreciendo la información en dos capas.
 2. El consentimiento expreso que deberá ser inequívoco, explícito y elegido de forma libre.
 3. La minimización de los datos, como una de las medidas de protección de datos desde el diseño y por defecto.
 4. La seudonimización o anonimización, de forma que se generen datos anonimizados a partir de datos personales aplicando una transformación que debe asegurar que la información adicional no permite la reidentificación.
 5. Las medidas técnicas según el ENS, en particular, las que permiten realizar el cifrado y la seudonimización, garantizar la confidencialidad, integridad, disponibilidad y resiliencia de los sistemas y servicios, las que garanticen la continuidad del negocio y aquellas que permiten la monitorización y la auditoría.
 6. El análisis de riesgos, realizando una gestión del riesgo con el fin de determinar las medidas para garantizar los derechos y libertades de las personas.
 7. La Evaluación de Impacto de Protección de Datos, cuando los tratamientos impliquen un riesgo alto para la protección de datos.
 8. La portabilidad de los datos siempre que el tratamiento esté basado en el consentimiento y/o se efectúe por medios automatizados.
 9. El derecho de supresión o derecho al olvido mediante el borrado y destrucción segura.
 10. La respuesta a Incidentes y la notificación de brechas de seguridad en el plazo de 72 horas.

Herramientas de cifrado y auditoría.

- El proceso de cifrado se debe ajustar a los datos sensibles para la organización y en el ámbito de los datos personales a los pertenecientes a categorías especiales:
 1. Origen étnico o racial.
 2. Opiniones políticas.
 3. Convicciones religiosas o filosóficas.
 4. Afiliación sindical.

5. Datos genéticos.
 6. Datos biométricos dirigidos a identificar de manera unívoca a una persona física.
 7. Datos relativos a la salud.
 8. Datos relativos a la vida sexual o las orientaciones sexuales de una persona física.
- El CPSTIC presenta en su sección Productos Cualificados las familias de redes virtuales privadas y comunicaciones móviles seguras de la categoría de Protección de las Comunicaciones, y en particular en la categoría de Protección de la información y soportes de la información.
 - Principales mecanismos criptográficos:
 1. Cifrado simétrico basado en clave privada y cifradores de bloque.
 2. El cifrado asimétrico basado: RSA, MODP y curvas elípticas acordadas.
 3. La firma electrónica para garantizar la integridad, autenticidad de origen y el no repudio.
 4. Los esquemas MAC para garantizar la integridad y autenticidad del origen.
 5. El protocolo TLS 1.2 y 1.3 para la protección de las comunicaciones, están autorizadas y recomendadas las versiones 1.2 y 1.3.
 6. El protocolo SSHv2 para la administración remota de los sistemas.
 7. El protocolo IPsec.
 - La instrucción técnica de seguridad de Auditoría de la Seguridad de los Sistemas de Información publicada en 2018 establece que cuando el sistema auditado tenga por objeto o incluya el tratamiento de datos personales, se tendrá en cuenta el RGPD.
 - Los dominios que se recomiendan se tengan en consideración en la realización con una auditoría de protección de datos son:
 1. El modelo organizativo con una correcta definición de roles y funciones.
 2. El funcionamiento del delegado de protección de datos y del encargado de protección de datos.
 3. La licitud de los tratamientos con la revisión de consentimientos, contratos, cláusulas informativas, la información incorporada en el pie de los correos electrónicos, la política de privacidad de la web, y la transparencia en la información
 4. La correcta actuación en la gestión de derechos con la revisión de los procedimientos y su publicidad, los formularios de solicitud para los interesados y los canales de comunicación.
 5. La aplicación de la privacidad desde el diseño, junto con la aplicación del principio de minimización de datos.
 6. El correcto registro de actividades de tratamientos, la revisión de la finalidad, plazos de conservación y accesibilidad.

7. La existencia de un análisis de riesgos y de una Evaluación de Impacto de la Protección de Datos, así como de la metodología y procedimientos para llevarlos a cabo.
 8. La existencia y seguimiento de un procedimiento de notificación de brechas.
 9. La correcta implantación de medidas de seguridad resultado de un plan de adecuación al ENS.
 10. El mantenimiento de los registros suficientes para demostrar el cumplimiento de la norma, incluida la ejecución de sus controles periódicos.
 11. La existencia de un plan de formación y de concienciación.
 12. La correcta ejecución de las transferencias internacionales si se diesen.
 13. El correcto desarrollo de los acuerdos de corresponsabilidad en el tratamiento de datos personales.
- Herramientas de la AEPD:
 1. FACILITA.
 2. EVALUA-RIESGO RGPD.
 3. GESTIONA.
 4. FACILITA-EMPRENDE.
 - Herramientas para la auditoría:
 1. GESTIONA.
 2. PILAR.
 3. AMPARO.

7 GLOSARIO

- RGPD: Reglamento General de Protección de Datos.
- LOPDGDD: Ley Orgánica de Protección de Datos y Garantía de Derechos Digitales.
- ENS: Esquema Nacional de Seguridad.
- AEPD: Agencia Española de Protección de Datos.
- RAT: Registro de actividades de tratamiento.
- PID: Plataforma de Intermediación de Datos.
- CCN-CERT: Centro Criptológico Nacional - Computer Emergency Response Team.
- CCN-STIC: Centro Criptológico Nacional – Seguridad de las Tecnologías de la Información y la Comunicación.
- CPSTIC: Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información
- EIPD: Evaluación de Impacto de Protección de Datos.
- SAT: Sistema de Alerta Temprana.
- CSCDA: Comisión Superior Calificadora de Documentos Administrativos.
- TLS: Transport Layer Security.
- PGP: Pretty Good Privacy.
- HSM: Módulo de Seguridad Hardware.
- SSH: Secure Shell.
- MAC: Message Authentication.
- VPN: Virtual Private Network.
- AES: Advanced Encryption Standard.
- RSA: Cifrado asimétrico Rivest, Shamir y Adleman.
- ZKP: Zero-Knowledge Proof.
- Pentesting test de penetración que consiste en atacar diferentes entornos o sistemas con el objetivo de detectar y prevenir posibles fallos.

8 TEST

8.1 PREGUNTAS DE TEST

- 1) En relación con los roles en materia de protección de datos:
 - a) El responsable de la actividad de tratamiento utiliza los datos para los fines establecidos y toma decisiones sobre su tratamiento.
 - b) El encargado almacena y procesa los datos siguiendo instrucciones del responsable del tratamiento.
 - c) El encargado puede si lo considera necesario, establecer otras finalidades a los datos que procesa.
 - d) La respuesta a y b son correctas.

- 2) Son obligaciones del responsable del tratamiento de datos personales:
 - a) Entre otras, el registro de actividades de tratamiento y la evaluación de impacto, pero no la notificación de brechas.
 - b) La notificación de brechas a la Autoridad de Control, pero no a los interesados.
 - c) La protección de datos desde el diseño y la protección de datos por defecto.
 - d) La elaboración de un catálogo de servicios.

- 3) Para el cumplimiento del deber de información, las aplicaciones deberán:
 - a) Mostrar toda la información lo más completa y detallada en una sola página con un botón aceptar en la parte inferior.
 - b) Mostrar la información en dos capas, una primera con información más básica y una segunda con información detallada.
 - c) Seis capas de información una para cada epígrafe de la que se deba ofrecer detalle.
 - d) La segunda capa será igual a la primera, pero en la lengua oficial de cada comunidad autónoma.

- 4) En la seudonimización de los datos se debe tener en cuenta:
- a) Que no sea posible la reidentificación de las personas.
 - b) Es habitual utilizar las funciones de hash para por su propiedad irreversible.
 - c) Una vez se tiene la información seudonimizada, no es necesario aplicar ninguna medida.
 - d) Las respuestas a y b son ciertas.
- 5) Para la adecuación de las aplicaciones y entornos a la normativa de protección de datos se debe cumplir:
- a) El ENS, el RGPD y la LOPDDGG
 - b) Solo el ENS como norma clave para la seguridad de la información
 - c) Solo el RGPD como norma clave para la protección de datos personales.
 - d) Solo el RGPD y la LOPDDGG, y en caso de riesgo alto, el ENS.
- 6) En relación con la determinación del riesgo:
- a) Siempre se debe realizar un análisis de riesgo y la EIPD solo si la organización pertenece a la AGE.
 - b) Siempre se debe realizar un análisis de riesgo y cuando se considere que hay un riesgo alto en relación con la protección de datos personales, una Evaluación de Impacto.
 - c) La Evaluación de Impacto sustituye al análisis de riesgos.
 - d) Una auditoría anual sustituye al análisis de riesgos.
- 7) El cifrado se debe aplicar:
- a) Siempre y en todo caso en las organizaciones.
 - b) Aplicarlo en todo caso a los datos sensibles.
 - c) A todos los datos personales.
 - d) Ninguna respuesta es cierta.
- 8) Las herramientas que pueden ayudar en la realización de una auditoría son:
- a) PILAR y AMPARO.

- b) REINA
 - c) INES
 - d) Ninguna de las anteriores.
- 9) En relación con el derecho de supresión
- a) Aplica a todos y cada uno de los ámbitos en los que se relacionan las personas.
 - b) Aplica únicamente al ámbito digital.
 - c) Implica suprimir todos los datos excepto los de copias de seguridad o *backup*.
 - d) Ninguna de las anteriores es cierta.

8.2 SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	d
2	c
3	b
4	d
5	a
6	b
7	b
8	a
9	b

9 BIBLIOGRAFÍA BÁSICA

9.1 BIBLIOGRAFÍA BÁSICA

1. Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales. <https://www.boe.es/eli/es/lo/2018/12/05/3>
2. Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. <https://www.boe.es/eli/es/rd/2022/05/03/311>
3. Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales. <https://www.boe.es/eli/es/lo/2021/05/26/7/con>
4. El Grupo de Trabajo del Artículo 29. Data Protection Working Party. Statement of the WP29 on encryption and their impact on the protection of individuals with regard to the processing of their personal data in the EU. Brussels, April 11 2018. <https://ec.europa.eu/newsroom/article29/items/622229/en>
5. Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información. [https://www.boe.es/eli/es/res/2018/03/27/\(2\)](https://www.boe.es/eli/es/res/2018/03/27/(2))
6. Política de gestión de documentos electrónicos (3ª EDICIÓN). 9. Guía de aplicación de eliminación [https://www.hacienda.gob.es/Documentacion/Publico/SGT/CATALOGO_SEFP/282_9.Guia%20de%20aplicacion%20de%20eliminacion%20\(acc\).pdf](https://www.hacienda.gob.es/Documentacion/Publico/SGT/CATALOGO_SEFP/282_9.Guia%20de%20aplicacion%20de%20eliminacion%20(acc).pdf)
7. Gestión del riesgo y evaluación de impacto en tratamientos de datos personales <https://www.aepd.es/es/documento/gestion-riesgo-y-evaluacion-impacto-en-tratamientos-datos-personales.pdf>
8. Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información. <https://www.boe.es/buscar/doc.php?id=BOE-A-2018-4573>
9. Ley Orgánica 3/2018, de 5 De diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales. Nuevas Obligaciones para el Sector Público. <https://www.aepd.es/sites/default/files/2019-10/novedades-lopd-sector-publico.pdf>
10. CCN-STIC 105 Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y la Comunicación (CPSTIC). <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/2536-ccn-stic-105-catalogo-de-productos-de-seguridad-de-las-tecnologias-de-la-informacion-y-la-comunicacion/file.html>

11. Taxonomía de productos STIC. Anexo E.1: Dispositivos de almacenamiento cifrado procedente de la Guía CCN-STIC 140 <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/3956-guia-140-anexo-e-1-almacenamiento-cifrado-de-datos/file.html>

9.2 BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

1. Introducción al Hash como técnica de Seudonimización de Datos Personales <https://www.aepd.es/es/documento/estudio-hash-anonimidad.pdf>
2. Anonimización y seudonimización <https://www.aepd.es/es/prensa-y-comunicacion/blog/anonimizacion-y-seudonimizacion>
3. Cifrado y Privacidad: cifrado en el RGPD <https://www.aepd.es/es/prensa-y-comunicacion/blog/cifrado-y-privacidad-cifrado-en-el-rgpd>
4. Cifrado y Privacidad II: El tiempo de vida del dato <https://www.aepd.es/es/prensa-y-comunicacion/blog/cifrado-y-privacidad-ii-el-tiempo-de-vida-del-dato>
5. Cifrado y Privacidad III: Cifrado Homomórfico <https://www.aepd.es/es/prensa-y-comunicacion/blog/cifrado-privacidad-iii-cifrado-homomorfo>
6. Cifrado y Privacidad IV: Pruebas de conocimiento cero <https://www.aepd.es/es/prensa-y-comunicacion/blog/cifrado-privacidad-iv-pruebas-conocimiento-cero>
7. Cifrado y Privacidad (V): la clave como dato personal <https://www.aepd.es/es/prensa-y-comunicacion/blog/cifrado-privacidad-iv-la-clave-como-dato-personal>
8. Requisitos para Auditorías de Tratamientos que incluyan IA <https://www.aepd.es/es/documento/requisitos-auditorias-tratamientos-incluyan-ia.pdf>
9. Adecuación al RGPD de tratamientos que incorporan Inteligencia Artificial. Una introducción. <https://www.aepd.es/sites/default/files/2020-02/adecuacion-rgpd-ia.pdf>
10. Guía para la contratación de auditorías de certificación del Esquema Nacional de Seguridad (ENS) <https://www.ccn-cert.cni.es/pdf/guias/informes-cocens/5132-ccn-cert-ic-02-20-guia-para-la-contratacion-de-auditorias-de-certificacion-del-esquema-nacional-de-seguridad-ens/file.html>
11. CCN-STIC 808 Verificación del cumplimiento del ENS <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/518-ccn-stic-808-verificacion-del-cumplimiento-de-las-medidas-en-el-ens/file.html>
12. El Grupo de Trabajo del Artículo 29. Directrices sobre el derecho a la portabilidad de los datos. https://sic.us.es/sites/default/files/pd/ngpd_portabilidad.pdf

13. Adaptación al RGPD en las Administraciones Públicas.
<https://www.aepd.es/sites/default/files/2019-10/infografia-adaptacion-rgpd-aapp.pdf>
14. Lista orientativa para tipos de tratamiento que no requieren evaluación de impacto relativa a la protección de datos según artículo 35.5 del RGPD:
<https://www.aepd.es/sites/default/files/2019-09/ListasDPIA-35.5l.pdf>
15. Lista de tipo de tratamiento de datos que requieren evaluación de impacto relativa a protección de datos art. 35.4 del RGPD: <https://www.aepd.es/sites/default/files/2019-09/listas-dpia-es-35-4.pdf>
16. Guía de Privacidad desde el diseño: <https://www.aepd.es/es/documento/guia-privacidad-desde-diseno.pdf>
17. Guía para clientes que contraten servicios de Cloud computing:
<https://www.aepd.es/sites/default/files/2019-12/guia-cloud-clientes.pdf>
18. Código de Buenas Prácticas en Protección de Datos para Proyectos Big Data
<https://www.aepd.es/sites/default/files/2019-09/guia-codigo-de-buenas-practicas-proyectos-de-big-data.pdf>
19. Guía 'Orientaciones y garantías en los procedimientos de anonimización de datos personales'.
<https://www.aepd.es/sites/default/files/2019-09/guia-orientaciones-procedimientos-anonimizacion.pdf>
20. Guía: 'Introducción al hash como técnica de seudonimización de datos personales':
<https://www.aepd.es/sites/default/files/2020-05/estudio-hash-anonimidad.pdf>
21. Guía 'La *K*-anonimidad como medida de la privacidad'.
<https://www.aepd.es/sites/default/files/2019-09/nota-tecnica-kanonimidad.pdf>
22. CCN-CERT IC-02/20, <https://www.ccn-cert.cni.es/pdf/guias/informes-cocens/5132-ccn-cert-ic-02-20-guia-para-la-contratacion-de-auditorias-de-certificacion-del-esquema-nacional-de-seguridad-ens/file.html>